EC-Council CEH v13 AI (312-50)

CEH v13 AI (312-50) Study Guide - Module 04: Enumeration

Source: 12 pages of screenshots from the official Module 04 theory videos (slides 1 to 39). Content marked "ADDED CONTEXT" comes from outside the screenshots. Items marked "verify" should be checked against current official sources. Items marked [UNCLEAR on page N] were too small or blurry to read with full confidence.

Table of Contents

1. Module at a Glance 4

2. Big Picture Map 6

3. Topic-by-Topic Guide 7

3.1 Learning Objectives of Module 04 [slide 1, page 1] 7
3.2 What is Enumeration? [slide 2, page 1] 7
3.3 NetBIOS Enumeration [slide 6, page 1] 9
3.4 NetBIOS Enumeration Tools: nbtstat and NetBIOS Enumerator [slide 7, page 1] 11
3.5 Enumerating Shared Resources Using Net View [slide 8, page 2] 13
3.6 SNMP (Simple Network Management Protocol) Enumeration [slide 11, pages 2 and 3] 14
3.7 LDAP Enumeration [slide 13, page 3] 16
3.8 NTP Enumeration and NTP Enumeration Commands [slide 15, page 4] 18
3.9 NFS Enumeration [slide 16, page 4] 19
3.10 SMTP Enumeration [slide 19, page 5] 21
3.11 SMTP Enumeration Tools: Nmap, Metasploit, smtp-user-enum, NetScanTools Pro [slide 19 cont'd, page 5] 23
3.12 DNS Enumeration Using Zone Transfer [slide 21, page 6] 25
3.13 DNSSEC Zone Walking [slide 23, page 6] 27
3.14 DNS Enumeration Using OWASP Amass [slide 24, page 7] 28
3.15 DNS and DNSSEC Enumeration Using Nmap [slide 25, page 7] 30
3.16 IPsec Enumeration [slide 29, page 8] 31
3.17 VoIP Enumeration [slide 30, page 9] 33
3.18 RPC Enumeration [slide 31, page 9] 35
3.19 Unix/Linux User Enumeration [slide 32, page 10] 36
3.20 SMB Enumeration (with AI) [slide 33, page 11] 37
3.21 Enumeration Countermeasures: SNMP, LDAP, NFS [slide 38, page 11] 39
3.22 Enumeration Countermeasures (Cont'd): SMTP, SMB, DNS [slide 39, page 12] 40
3.23 AI-Assisted Enumeration: Prompts, ShellGPT, and Limits (ADDED CONTEXT) 41

4. Tool Encyclopedia 44

4.1 NetBIOS, Windows, and SMB Tools 44
4.2 SNMP, LDAP, NTP, and NFS Tools 44
4.3 SMTP and DNS Tools 45
4.4 IPsec, VoIP, RPC, Linux/Unix, and AI Tools 46

5. Command Sheet 48

5.1 nbtstat 48
5.2 net view 49
5.3 snmpwalk 50
5.4 Nmap Scripts for Enumeration 51
5.5 ldapsearch 53
5.6 ntptrace 54
5.7 ntpdc 55
5.8 ntpq 56
5.9 showmount 56
5.10 rpcinfo 57
5.11 telnet for SMTP (VRFY, EXPN, RCPT TO) 58
5.12 smtp-user-enum 59
5.13 Metasploit Modules: smtp_enum and SIP options 60
5.14 dig 61
5.15 nslookup 62
5.16 dnsrecon 63
5.17 ldns-walk 64
5.18 amass 65
5.19 ike-scan 66
5.20 sgpt (ShellGPT) 67
5.21 svmap 68

5.22 rusers 68
5.23 rwho 69
5.24 finger 70
5.25 SMB Tools: enum4linux, SMBMap, nullinux 70

6. Ports, Protocols, Standards and Acronyms 72
6.1 Service Ports Used in Enumeration 72
6.2 NetBIOS Suffix Codes 73
6.3 SMTP Reply Codes 73
6.4 SNMP Quick Facts 73
6.5 DNS and DNSSEC Records 74
6.6 SIP Methods 74
6.7 Rare Protocols in Plain Words 75
6.8 Acronyms Used in This Module 75

7. Attack vs Countermeasure and Look-alike Comparisons 77
7.1 Attacks and Their Countermeasures 77
7.2 Look-alike Pairs 78

8. Exam Cheat Sheet 80
8.1 Keyword to Answer 80
8.2 Must-Memorize Lists 81
8.3 Numbers and Defaults 82
8.4 Pick the BEST Option Rules 82
8.5 Last-Minute Mnemonics 83

9. Practice Questions 84

10. Flashcards 93

11. Glossary 95

12. Coverage Report 97
12.1 Page to Section Map 97
12.2 [UNCLEAR] Items 97
12.3 Items to Double Check 98
12.4 Confirmation 98

1. Module at a Glance

Module: 04 - Enumeration (EC-Council CEH v13 AI).

What this module is (5 lines):

1. Enumeration is the step after scanning. The attacker opens an active connection to a service and asks direct questions.
2. The answers give usernames, machine names, shares, routing data, service settings, and banners.
3. The module goes service by service: NetBIOS, SNMP, LDAP, NTP, NFS, SMTP, DNS, IPsec, VoIP, RPC, Linux/Unix, and SMB.
4. For each service it shows the commands and tools, and where the slides allow, an AI prompt (ChatGPT, ShellGPT) that builds the Nmap command.
5. It ends with countermeasures for SNMP, LDAP, NFS, SMTP, SMB, and DNS.

Why it matters: Enumeration turns "port 445 is open" into "these are the users, shares, and OS version". Every later attack (password guessing, exploitation) depends on that detail. The exam checks that you can match a service to its port, tool, command, and fix.

What the exam usually asks from it:

- Which service uses which port (SNMP 161, LDAP 389, SMB 445, NFS 2049, SMTP 25, ISAKMP 500, SIP 5060).
- Which tool or command fits the job: nbtstat, net view, snmpwalk, ntpq, showmount, rpcinfo, VRFY, dig axfr, ike-scan, svmap, finger, enum4linux.
- What a NetBIOS suffix code means (00, 03, 20, 1B, 1D).
- What each SMTP command does (VRFY, EXPN, RCPT TO) and what a 250 versus a 550 reply means.
- Zone transfer versus DNSSEC zone walking.
- Which countermeasure fits which service (SNMPv3, LDAP over SSL or STARTTLS, block NFS 2049, disable open relay, RestrictNullSessAccess, split resolvers).
- Reading short command output and naming the flag that produced it.

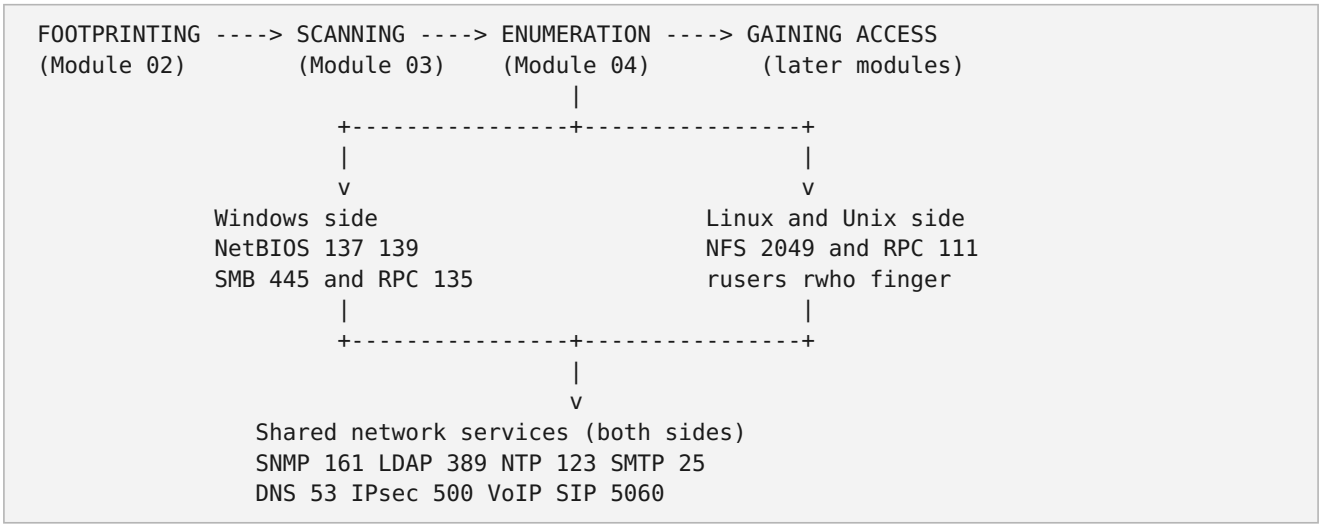
The 10 things to remember most:

1. Enumeration = an active connection plus directed queries to pull out usernames, machine names, shares, and services. It follows scanning and mostly happens inside the network (intranet).
2. A NetBIOS name is 16 ASCII characters: 15 for the device name and the 16th for the service type. Key codes: 00 workstation or domain, 03 messenger, 20 file server, 1B domain master browser (PDC), 1D master browser.
3. `nbtstat -a` (name) or `nbtstat -A` (IP) shows a remote NetBIOS name table. `net view \\host` lists its shares.
4. SNMP uses UDP 161. Default community strings are public (read) and private (read-write). The fix is SNMPv3, which encrypts.

5. LDAP uses TCP 389 and talks to a Directory System Agent (DSA). It is plain text by default, so use SSL or STARTTLS.
6. NTP tools: ntptrace (follow the chain to the source), ntpdc (monitor ntpd), ntpq (monitor and check performance).
7. NFS uses port 2049. `showmount -e host` lists exports. `rpcinfo -p host` lists RPC programs (portmapper is port 111).
8. SMTP enumeration uses VRFY (check a user), EXPN (expand a list), RCPT TO (name a recipient). A valid user gets 250. An unknown user gets 550.
9. DNS: a zone transfer (dig axfr) works only if the server allows it. Zone walking follows NSEC records in DNSSEC. Amass and Nmap scripts map sub-domains.
10. Fixes: turn off or upgrade the service, block the port (139, 445, 2049, 161), restrict anonymous access (RestrictNullSessAccess), disable open relay, and keep DNS resolvers internal.

2. Big Picture Map

Enumeration sits between scanning and gaining access. Scanning says which doors are open. Enumeration talks to what is behind each door.



How each service maps to what the attacker gets and the main tool:

Service	Port	What the attacker gets	Main tool or command
NetBIOS	UDP 137, TCP 139	Names, domain, shares	nbtstat, NetBIOS Enumerator
Shares	TCP 445	Share list	net view
SNMP	UDP 161	Devices, ARP, routes	snmpwalk, snmp-check
LDAP	TCP 389	Users, addresses, departments	ldapsearch, AD Explorer
NTP	UDP 123	Hosts, clients, OS	ntptrace, ntpdc, ntpq
NFS	TCP/UDP 2049	Exported folders	showmount, rpcinfo
SMTP	TCP 25	Valid users	VRFY, EXPN, RCPT TO
DNS	TCP/UDP 53	Hosts, records	dig, nslookup, Amass
IPsec	UDP 500	VPN gateway, algorithms	ike-scan
VoIP	5060 5061	Phones, PBX, extensions	svmap
RPC	135 and 111	Services on RPC ports	rpcinfo, NetScanTools
Linux users	RPC, 79	Logged-in users	rusers, rwho, finger
SMB	TCP 445	OS banner, shares	Nmap, SMBMap, enum4linux

The same flow works at any service:

1. Find the port (scanning).
2. Connect and ask (enumeration command or tool).
3. Read the answer (users, shares, versions).
4. Feed the answer into the next phase (password attack, exploit).
5. Defender removes or locks the service so the answer is empty.

3. Topic-by-Topic Guide

The topics follow the order of your screenshots (slide numbers in brackets).

3.1 Learning Objectives of Module 04 [slide 1, page 1]

What it is: The first slide lists seven goals for the module. They are the exam blueprint for this module.

No.	Objective	Where it is in this guide
01	Explain enumeration concepts	3.2
02	NetBIOS enumeration techniques	3.3, 3.4, 3.5
03	SNMP and LDAP enumeration	3.6, 3.7
04	NTP and NFS enumeration	3.8, 3.9
05	SMTP and DNS enumeration	3.10 to 3.15
06	IPsec, VoIP, RPC, Linux/Unix, SMB	3.16 to 3.20
07	Enumeration countermeasures	3.21, 3.22

[UNCLEAR on page 1]: the wording of objectives 03 to 06 is small on the slide. The grouping above is the best reading and matches the order of the later slides.

How to use it: Treat each row as a question family. If you can explain, run (on paper), and defend against each service on the list, you cover the module.

EXAM FOCUS:

- The exam does not ask the objectives list itself. It asks the content behind each row.
- Trap: DNS has several enumeration styles (zone transfer, zone walking, Amass, Nmap). They are different techniques. Do not merge them.

Memory trick: Remember the order as four steps: the Windows side first (NetBIOS), then the shared services (SNMP, LDAP, NTP, NFS, SMTP, DNS), then VPN, phone, RPC, Linux, and SMB, then defense.

3.2 What is Enumeration? [slide 2, page 1]

What it is: Enumeration means creating an active connection to a target system and sending directed queries to get more information. The attacker uses what he finds to pick attack points and to run password cracking (guessing or breaking passwords) against the system's resources. These techniques run mostly in an intranet environment (inside the organization's network), so the attacker must already have a path in.

Analogy: Scanning is walking around a building and checking which doors are unlocked. Enumeration is stepping inside, opening the staff directory on the wall, and writing down every name, room, and phone extension.

Information the slide says an intruder enumerates:

Item	Simple meaning
Network resources	Printers, servers, and devices others can use
Network shares	Folders and drives shared over the network
Routing tables	Lists of paths that tell a router where to send traffic
Audit and service settings	What is logged and which services run
SNMP and FQDN details	Device data from SNMP and full host names
Machine names	Computer names on the network
Users and groups	Account names and the groups they belong to
Applications and banners	Installed software and service greeting text

A **banner** is the text a service prints when you connect. It often shows the product name and version. An **FQDN** (fully qualified domain name) is the complete host name, such as `mail.example.com`.

How it works:

1. The attacker finishes scanning and knows which ports are open.
2. He connects to a service on one open port (for example SNMP on UDP 161).
3. He sends a directed query that the service is built to answer.
4. The service replies with usernames, shares, or settings.
5. He records the answers and picks the next step (guess passwords, exploit a version).

```
SCANNING                        ENUMERATION
finds open ports      ---->     asks the service questions
(port 445 is open)              (which users and shares and OS)
```

Real-world use: A penetration tester on an internal assessment finds port 161 open on a switch. She queries it with the default community string "public" and gets the ARP table, the routing table, and the device name. She reports that the switch leaks the network layout and recommends SNMPv3. The client fixes it before a real attacker finds it.

Tools and commands used here: All tools in this module (nbtstat, net view, snmpwalk, ldapsearch, ntpq, showmount, telnet, dig, ike-scan, svmap, finger, Nmap). Details are in sections 4 and 5.

AI angle: An attacker can ask a generative AI tool to build the right enumeration command from plain English. A defender can ask the same tool to explain output or write a report. Example prompt: "Write the Nmap command to enumerate SMB on 10.10.1.22 and explain each flag." AI output can contain wrong flags, so always read it before running it.

ADDED CONTEXT: The standard CEH list of enumeration techniques is:

1. Extract usernames using email IDs (the part before the @ is often the login name).
2. Extract information using default passwords (vendor defaults that nobody changed).
3. Extract usernames using SNMP.

4. Brute force Active Directory (guess many passwords against the directory).
5. Extract information using DNS zone transfer.

> **ADDED CONTEXT:** Enumeration is noisy. It creates logs and can trigger an IDS (intrusion detection system). On the exam, enumeration is "active", needs a connection to the target, and normally follows scanning.

Countermeasures and defense: Close or restrict the services that answer (details in 3.21 and 3.22), segment the network, and log and alert on repeated queries.

EXAM FOCUS:

- Keywords: "active connection", "directed queries", "usernames, machine names, shares, services" -> enumeration.
- Keyword: "intranet environment" -> enumeration is done from inside the network.
- Trap: Footprinting and scanning find general data (domain names, open ports). Enumeration finds specific data (accounts, shares, versions).
- Look-alike: scanning versus enumeration. Scanning asks "is it open?". Enumeration asks "what is inside?".

Memory trick: The eight enumerated items spell a silly sentence: **N**aughty **N**ephews **R**arely **A**dmit **S**tealing **M**any **U**nripe **A**pples = Network resources, Network shares, Routing tables, Audit and service settings, SNMP and FQDN details, Machine names, Users and groups, Applications and banners.

3.3 NetBIOS Enumeration [slide 6, page 1]

What it is: NetBIOS (Network Basic Input/Output System) is an old Windows networking interface that lets programs on different computers find each other and share files and printers. On the slide, a NetBIOS name is a unique string of 16 ASCII characters that identifies a network device over TCP/IP. The first 15 characters are the device name. The 16th character is the **suffix code** that says which service or record type the name stands for.

Analogy: A name badge with 15 letters for the person's name and one last symbol for the role: greeter, file clerk, or manager. Same person, different symbol, different job.

What the attacker gets (slide):

- The list of computers that belong to a domain.
- The list of shares on the individual hosts in the network.
- Policies and passwords.

NetBIOS name list (from the slide):

Name	Code	Type	Information obtained
host name	00	UNIQUE	Hostname
domain	00	GROUP	Domain name
host name	03	UNIQUE	Messenger service on the computer

Name	Code	Type	Information obtained
username	03	UNIQUE	Messenger service for the logged-in user
host name	20	UNIQUE	Server service running
domain	1D	GROUP	Master browser name for the subnet
domain	1B	UNIQUE	Domain master browser, identifies the PDC

- **UNIQUE** means one machine owns the name. **GROUP** means many machines can share it.
- **PDC** (primary domain controller) is the server that holds the master copy of the domain accounts in older Windows domains.
- **Master browser** is the machine that keeps the list of computers visible in "Network Neighborhood".

> **TRAP:** The slide shows code 1D as GROUP, but the nbtstat output on the next slide shows `WORKGROUP <1D> UNIQUE`. Microsoft documents 1D as UNIQUE (verify). If a question asks for the master browser code, the answer is 1D. If it asks for the PDC or domain master browser, the answer is 1B.

Note on the slide: NetBIOS name resolution is not supported by Microsoft for IPv6. NetBIOS enumeration only works on IPv4 networks.

ADDED CONTEXT: More suffix codes the exam may use:

Code	Type	Meaning
01	GROUP	**MSBROWSE**, master browser announcements
1C	GROUP	Domain controllers for the domain
1E	GROUP	Browser service election
1F	UNIQUE	NetDDE service
21	UNIQUE	RAS server service

NetBIOS runs on three ports: UDP 137 (name service), UDP 138 (datagram service), and TCP 139 (session service). Modern SMB uses TCP 445 and does not need NetBIOS.

How it works:

1. The attacker finds a host with port 137 or 139 open.
2. He asks the host for its **name table** (the list of NetBIOS names registered on it).
3. The host replies with names, name types, and the MAC address.
4. The suffix codes show what the host does (workstation, file server, domain controller).
5. The attacker uses the host list, user names, and shares as targets.

Real-world use: On an internal test, a tester asks every host in 10.10.1.0/24 for its name table. One host returns code 1B, so it is the domain master browser and a PDC. The tester marks it as the highest-value target and reports that NetBIOS over TCP/IP should be off.

Tools and commands used here: nbtstat, NetBIOS Enumerator, Nmap, Global Network Inventory, Advanced IP Scanner, Hyena (all in 3.4).

AI angle: Prompt: "Write an Nmap command that reads NetBIOS names from 10.10.1.0/24 over UDP." A good answer is `nmap -sU -p 137 --script nbstat 10.10.1.0/24`. The attacker saves time. The defender can use the same prompt to audit their own range.

Countermeasures and defense:

- Turn off NetBIOS over TCP/IP on adapters that do not need it.
- Block ports 137, 138, and 139 at the firewall (the slide set also says disable TCP 139 and 445, see 3.22).
- Do not expose file and printer sharing on servers that do not need it.

EXAM FOCUS:

- Keywords: "16 character", "15 for the device name, 16th for service" -> NetBIOS name.
- Common questions: "What does code 1B show?" (domain master browser, PDC). "What does 20 show?" (server service). "What does 03 show?" (messenger service).
- Trap: UNIQUE versus GROUP. Hostname and server service are UNIQUE. Domain name is GROUP.
- Look-alike: NetBIOS (names, ports 137-139) versus SMB (file sharing, port 445).

Memory trick: Read the codes as a story: "00 is Who you are, 03 is Messages, 20 is Files, 1B is the Big boss (PDC), 1D is the local Director (subnet master browser), 1E is Elections."

3.4 NetBIOS Enumeration Tools: nbtstat and NetBIOS Enumerator [slide 7, page 1]

What it is: The slide shows two tools. **Nbtstat** is a built-in Windows command-line utility that shows NetBIOS over TCP/IP statistics and name tables. **NetBIOS Enumerator** is a free GUI tool that scans an IP range and lists NetBIOS data.

Analogy: nbtstat is asking one person at a time "what is your badge?". NetBIOS Enumerator is walking down a whole corridor and reading every badge.

Nbtstat on the slide: "Run the nbtstat command `nbtstat -a <IP address of the remote machine>` to obtain the NetBIOS name table of a remote computer." The screenshot runs `nbtstat -a 10.10.1.11`. The output is a table with three columns:

Column	Meaning
Name	The NetBIOS name, with the suffix code in angle brackets
Type	UNIQUE or GROUP
Status	Registered means the name is active

The sample output shows names such as `WINDOWS11 <00> UNIQUE`, `WORKGROUP <00> GROUP`, `WINDOWS11 <20> UNIQUE`, `WORKGROUP <1E> GROUP`, `WORKGROUP <1D> UNIQUE`, and `..__MSBROWSE__.<01> GROUP`. The last line shows the **MAC address** (the hardware address of the network card) of the remote machine. A full line-by-line reading is in section 5.1.

> **TRAP:** Official Microsoft help says `-a` takes a remote computer name and `-A` takes an IP address. The slide uses `-a` with an IP. In a question that offers both `-a` and `-A` for an IP address, choose `-A`. If only `-a` appears with an IP (as on the slide), choose it. See [UNCLEAR on page 1] in the report.

NetBIOS Enumerator (nbtenum.sourceforge.net):

- The attacker enters an **IP range** (start and end address).
- The tool queries every address in the range.
- It returns NetBIOS names, usernames, domain names, and MAC addresses.

Other NetBIOS enumeration tools (slide): Nmap (nmap.org), Global Network Inventory (magnetosoft.com), Advanced IP Scanner (advanced-ip-scanner.com), Hyena (systemtools.com).

How it works:

1. Choose one host (nbtstat) or an IP range (NetBIOS Enumerator).
2. The tool sends a NetBIOS Node Status request to UDP 137.
3. Each host replies with its name table.
4. The tool shows names, types, and MAC addresses.

Real-world use: A tester has a list of 254 addresses. She loads the range into NetBIOS Enumerator and sees that 40 hosts answer. She exports the names and picks the servers (code 20) for a share check.

AI angle: Prompt: "Explain this nbtstat output and tell me which host is a file server." A chatbot can read the table and say that code 20 marks the server service. Never paste real client data into a public AI tool.

Countermeasures and defense: Same as 3.3. Turn off NetBIOS over TCP/IP and block UDP 137.

EXAM FOCUS:

- Keyword: "NetBIOS name table of a remote computer" -> nbtstat.
- Keyword: "IP range" and "GUI" with NetBIOS -> NetBIOS Enumerator.
- Trap: nbtstat is a Windows command. Do not choose it for a Linux-only scenario (use nbtscan or Nmap there).
- Look-alike: nbtstat (NetBIOS names) versus netstat (TCP connections). One letter apart.

Memory trick: "nbtstat = NetBIOS-over-TCP status." Capital A means Address: `-A` = IP Address.

3.5 Enumerating Shared Resources Using Net View [slide 8, page 2]

What it is: Net View is a built-in Windows command. The slide says it is used to obtain a list of all the **shared resources** of a remote host or workgroup. A **share** is a folder, drive, or printer that a computer offers to others over the network.

Analogy: Knocking on an office door and asking the receptionist for a printed list of every cabinet the office lets visitors open.

Net View commands (slide):

```
net view \\<computername>
net view /domain:<domain name>
```

Demo on the slide: `net view \\10.10.1.22 /ALL`

```
Shared resources at \\10.10.1.22

Share name   Type   Used as   Comment
ADMIN$       Disk             Remote Admin
C$           Disk             Default share
IPC$         IPC              Remote IPC
NETLOGON     Disk             Logon server share
SYSVOL       Disk             Logon server share
Users        Disk
The command completed successfully.
```

How to read the output:

- **ADMIN$** is the hidden share for the Windows folder. Administrators use it for remote management.
- **C$** is the default hidden share for the C: drive.
- **IPC$** is the share for inter-process communication (named pipes). Attackers use it for null sessions (see 3.20).
- **NETLOGON** and **SYSVOL** are logon server shares. They exist on domain controllers and hold logon scripts and group policy files.
- **Users** is a normal share that exposes user profile folders.
- A share name that ends in `$` is a **hidden (administrative) share**. It does not show in normal browse lists. The `/ALL` switch makes Net View show them.

How it works:

1. The attacker types `net view \\target /ALL` from a Windows command prompt.
2. Windows contacts the target over SMB (TCP 445, or 139).
3. The target lists its shares.
4. The attacker notes which shares allow access.

Real-world use: A tester checks a file server and sees a share called `Users`. He opens it with a normal domain account and finds scripts that contain a service password. This is a classic finding.

Tools and commands used here: `net view`, plus `net use` (connect to a share) and `net share` (list local shares) as ADDED CONTEXT.

AI angle: Prompt: "List the Windows commands to find shared folders on 10.10.1.22." AI usually returns net view, net use, and PowerShell `Get-SmbShare` (local) or `smbclient -L` from Linux. Confirm each one before use.

Countermeasures and defense: Remove shares that nobody needs, restrict share permissions to named users, disable SMB on internet-facing servers, and block TCP 139 and 445 (see 3.22).

EXAM FOCUS:

- Keyword: "list of shared resources of a remote host" -> `net view`.
- Syntax questions: `net view \\computer` (one host) versus `net view /domain:name` (computers in a domain).
- Trap: `net view` lists shares. `net user` lists accounts. `net use` connects to a share.
- Look-alike: nbtstat (NetBIOS names) versus net view (shares).

Memory trick: "View = Visible shares." Double backslash `\\` always comes before a computer name.

3.6 SNMP (Simple Network Management Protocol) Enumeration [slide 11, pages 2 and 3]

What it is: SNMP is a protocol that network managers use to monitor and control devices such as routers, switches, printers, and servers. On the slide, attackers use SNMP **default community strings** to extract information about a device. A **community string** works like a password for SNMP version 1 and 2c. Attackers enumerate SNMP to learn about network resources such as hosts, routers, devices, and shares, and about network information such as ARP tables, routing tables, and traffic.

Analogy: A building's facilities panel. If the panel password is still "public", any visitor can read every meter and map the whole building.

ADDED CONTEXT: SNMP parts the exam likes:

Part	Simple meaning
Managed device	Any device with an SNMP agent (router, switch, printer)
Agent	Software on the device that answers SNMP requests
NMS	Network management station, the console that asks questions
MIB	Management Information Base, the database of device values
OID	Object Identifier, the number path that names one value

- A **MIB** is a tree. Each value has an **OID** such as `1.3.6.1.2.1.1.1.0`, which means system description (sysDescr).
- **Read-only community:** default string `public`. It lets a client read values.
- **Read-write community:** default string `private`. It lets a client read and change values. This is more dangerous.

- SNMP uses **UDP port 161** for requests and **UDP port 162** for traps (alerts the device sends on its own).
- SNMPv1 and SNMPv2c send the community string in clear text. **SNMPv3** adds authentication and encryption.
- Request types: GetRequest, GetNextRequest, GetBulkRequest, SetRequest, plus Response, Trap, and InformRequest.

How it works:

1. The attacker scans UDP 161 and finds an open SNMP agent.
2. He tries default community strings (public, private).
3. If one works, he walks the MIB, which means he asks for every value in order.
4. The device returns system description, uptime, interfaces, ARP table, routing table, running processes, and Windows user names.
5. He uses this data to map the network and plan the next attack.

Demos on the slide: SnmpWalk and Nmap

SnmpWalk (Linux, net-snmp package). The command shown is best read as:

```
snmpwalk -v1 -c public 10.10.1.22
```

Nmap with a script that lists running processes over SNMP:

```
nmap -sU -p 161 --script=snmp-processes 10.10.1.22
```

The SnmpWalk screenshot returns lines such as the hardware and Windows build string, the system uptime, and the host name. The Nmap screenshot returns `161/udp open snmp` followed by a list of processes, for example `System Idle Process`, `System`, `svchost.exe`, and `Registry`. A full output reading is in sections 5.3 and 5.4. [UNCLEAR on page 2]: the exact values in the SnmpWalk output are too small to read, so section 5.3 uses a sample.

Other SNMP enumeration tools (slide): snmp-check (nothink.org), SoftPerfect Network Scanner (softperfect.com), Network Performance Monitor (solarwinds.com), OpUtils (manageengine.com).

ADDED CONTEXT: Close alternatives: `snmpget` (one value), `snmpgetnext`, `snmpbulkwalk` (faster walk), `onesixtyone` (fast community string guessing), and Nmap scripts `snmp-brute`, `snmp-info`, `snmp-sysdescr`, `snmp-interfaces`, `snmp-netstat`, `snmp-win32-users`, `snmp-win32-services`, and `snmp-win32-software`.

Real-world use: A tester finds a network printer with SNMP on and the community string unchanged. A walk returns the printer's IP, MAC, and the names of the servers that print to it. She uses the server names for the next step and recommends SNMPv3.

AI angle: Prompt: "Give me a one-line Nmap command to list Windows users over SNMP on 10.10.1.22 using the public community." Expected idea: `nmap -sU -p 161 --script snmp-win32-users 10.10.1.22`. Defenders can ask AI to turn a long snmpwalk dump into a summary of risky values.

Countermeasures and defense (slide, expanded in 3.21):

- Remove the SNMP agent or turn off the SNMP service.
- If you must keep it, change the default community string names.
- Upgrade to SNMPv3, which encrypts passwords and messages.
- Use the Group Policy option "Additional restrictions for anonymous connections".

EXAM FOCUS:

- Keywords: "default community strings", "ARP tables, routing tables" -> SNMP enumeration.
- Port: UDP 161 (agent), UDP 162 (trap).
- Nmap needs `-sU` because SNMP is UDP. A TCP scan (`-sS`) will not find it.
- Trap: "public" is read-only by default and "private" is read-write by default. Do not swap them.
- Fix to pick: "SNMPv3" beats "change the string" when both are offered, because v3 encrypts.

Memory trick: "SNMP = 161 Says Nothing Much Privately" (161 = request port). Community: "Public reads, Private writes."

3.7 LDAP Enumeration [slide 13, page 3]

What it is: LDAP (Lightweight Directory Access Protocol) is an internet protocol for accessing distributed directory services. A **directory** is an organized database of people, computers, and resources. Microsoft Active Directory is the best-known example and it speaks LDAP.

On the slide, a client starts an LDAP session by connecting to a **directory system agent (DSA)** on **TCP port 389** and then sends an operation request to the DSA. The DSA is the LDAP server process that holds the directory and answers requests. Attackers query the LDAP service to gather information such as **valid usernames, addresses, and departmental details**, which they use for further attacks.

Analogy: A company phone book with a helpful receptionist. If she answers anyone who asks, an outsider can copy every name, room, and department.

How it works:

1. The client connects to the DSA on TCP 389.
2. The client **binds** (logs in). An **anonymous bind** means no username and no password.
3. The client sends a search request with a base (where to start) and a filter (what to find).
4. The DSA returns matching entries with their attributes (name, mail, phone, department).
5. The attacker saves usernames and email addresses for password guessing and phishing.

ADDED CONTEXT: LDAP names look like this:

```
cn=John Smith,ou=Sales,dc=example,dc=com
```

Part	Meaning
DN	Distinguished Name, the full path of an entry
CN	Common Name, the entry's own name
OU	Organizational Unit, a department or folder
DC	Domain Component, one piece of the domain name

Ports: 389 (LDAP, plain text unless StartTLS), 636 (LDAPS, LDAP over SSL/TLS), 3268 (Global Catalog), 3269 (Global Catalog over SSL/TLS).

Demos on the slide:

- **Manual LDAP enumeration:** typed commands in a terminal, with the result highlighted. Best reading: `ldapsearch`.
- **Automated LDAP enumeration:** an Nmap run with an LDAP script, with many entries in the output. Best reading: `nmap -p 389 --script ldap-search 10.10.1.22`.

[UNCLEAR on page 3]: both screenshots are too small to read exactly. The readings above are the likely commands. See section 5.5 and 5.4.

Other LDAP enumeration tools (slide): Softerra LDAP Administrator (ldapadministrator.com), ldapsearch (linux.die.net), AD Explorer (Microsoft docs), LDAP Admin Tool (ldapsoft.com).

Real-world use: A tester finds TCP 389 open on a domain controller that allows anonymous binds. One ldapsearch command returns 900 user accounts with departments. She builds a username list and tests for weak passwords. The report tells the client to disable anonymous binds and require LDAPS.

Tools and commands used here: ldapsearch, Nmap (`ldap-rootdse`, `ldap-search`, `ldap-brute`), Softerra LDAP Administrator, AD Explorer, LDAP Admin Tool.

AI angle: Prompt: "Write an ldapsearch command to list all user entries from dc=example,dc=com on 10.10.1.22 with an anonymous bind, and explain each flag." The tool returns a command with `-x`, `-H`, and `-b`. A defender can ask AI to review an ldapsearch dump for sensitive attributes.

Countermeasures and defense (slide):

- LDAP traffic is sent unsecured by default. Use **SSL or STARTTLS** to encrypt it.
- Select a username different from your email address, and enable account lockout.
- Use NT LAN Manager (NTLM), Kerberos, or any basic authentication mechanism to limit access to legitimate users.

ADDED CONTEXT: Also disable anonymous binds and block 389 and 3268 from untrusted networks.

EXAM FOCUS:

- Keywords: "directory system agent", "TCP port 389", "valid usernames, addresses, departmental details" -> LDAP enumeration.
- Fix keywords: "SSL or STARTTLS" -> encrypt LDAP. "different from your email address" -> hard to guess login names.
- Trap: LDAP is port 389. LDAPS is 636. SNMP is 161. Do not mix them.
- Look-alike: LDAP (directory data) versus NetBIOS (names and shares).

Memory trick: "LDAP = Look up Directory Addresses and People. DSA listens on 389." 3-8-9: "three-eight-nine, directory is mine."

3.8 NTP Enumeration and NTP Enumeration Commands [slide 15, page 4]

What it is: NTP (Network Time Protocol) keeps the clocks of computers in sync. It uses **UDP port 123**. A computer asks an NTP server "what time is it?". An NTP server also knows about its peers and clients. On the slide, attackers query the NTP server to gather valuable information such as the **list of connected hosts and clients' IP addresses** in a network, their **system names**, and their **OSs**.

Analogy: The office wall clock that everyone checks. The person who winds it also keeps a list of everyone who asked for the time.

The three commands on the slide:

Command	Job	Syntax
ntptrace	Traces a chain of NTP servers back to the primary source	ntptrace [-n] [-m maxhosts] [servername/IP]
ntpdc	Monitors operation of the NTP daemon, ntpd	ntpdc [-ilnps] [-c command] [host] [...]
ntpq	Monitors ntpd operations and determines performance	ntpq [-inp] [-c command] [host] [...]

- **ntpd** is the NTP daemon (the background program that runs on the server).
- **Stratum** is the distance from the real time source. Stratum 0 is the atomic or GPS clock. Stratum 1 servers connect directly to it. Each hop adds 1.
- The ntpdc screenshot lists many sub-commands (for example `peers`, `listpeers`, `showpeer`, `sysinfo`, `sysstats`, `monlist`, `reslist`, `restrict`, `version`). The callout says these ntpdc queries can be used to obtain additional NTP server information.
- The ntpq screenshot also lists many sub-commands (for example `peers`, `associations`, `readvar`, `readlist`, `sysinfo`, `version`). The callout says the same.
- [UNCLEAR on page 4]: the full lists on the screenshots are tiny. Only the common sub-commands are named above.

How it works:

1. The attacker finds UDP 123 open on a host.
2. He runs `ntpq -p host` or `ntpdc -c monlist host` to ask about peers and clients.

3. The server replies with its peers, their stratum, delay, and offset values.
4. The attacker learns host names, client addresses, and sometimes the OS in the system variables.
5. He uses the address list for scanning and targeting.

ADDED CONTEXT:

- The `monlist` request returns the last clients that talked to the server. It was abused in NTP amplification DDoS attacks (a small request gets a big reply sent to a spoofed victim). Modern ntpd removed it (CVE-2013-5211, verify).
- `ntpdc` is old. Newer systems use `ntpq` and chrony.
- In `ntpq -p` output the columns are remote, refid, st (stratum), t (type), when, poll, reach, delay, offset, jitter.

Real-world use: A tester runs `ntpq -p` against a time server and sees six internal addresses listed as peers. Those are six hosts she did not find with a normal scan. She adds them to her scope.

Tools and commands used here: ntptrace, ntpdc, ntpq, Nmap scripts `ntp-info` and `ntp-monlist` (ADDED CONTEXT).

AI angle: Prompt: "Explain the difference between ntpdc, ntpq, and ntptrace and give one command for each against 10.10.1.5." AI can give a quick training table. Always check the version of ntpd first because old commands may be removed.

Countermeasures and defense: The slides do not list NTP fixes. ADDED CONTEXT: update ntpd, restrict queries in `ntp.conf` (for example with `restrict default noquery`), disable monlist, and allow UDP 123 only from known clients.

EXAM FOCUS:

- Keywords: "chain of NTP servers back to the primary source" -> ntptrace. "monitors operation of the NTP daemon" -> ntpdc. "determines performance" -> ntpq.
- Port: UDP 123.
- Trap: ntpdc and ntpq both monitor ntpd. The slide separates them by the words "operation" (ntpdc) and "performance" (ntpq).
- Look-alike: ntptrace (follow servers upward) versus ntpq -p (list peers).

Memory trick: "trace = Track the chain. dc = Daemon Control. q = Quality of performance (or Query)."

3.9 NFS Enumeration [slide 16, page 4]

What it is: NFS (Network File System) lets one computer use a folder on another computer as if it were local. The slide says the NFS system is generally implemented on a computer network where **centralization of data** is required for critical resources. NFS enumeration enables attackers to identify the **exported directories**, the **list of clients** connected to the NFS server along with their **IP addresses**, and the **shared data** associated with those IP addresses.

Analogy: A shared company cabinet in the hallway. NFS enumeration is asking the cabinet owner for the list of drawers that are open and who has a key.

Tools on the slide: RPCScan and SuperEnum. [UNCLEAR on page 4]: the slide text reads "RPSCan"; the tool is known as RPCScan. SuperEnum is a script that runs several enumeration commands in one go.

The two commands on the slide:

```
showmount -e 10.10.1.9
rpcinfo -p 10.10.1.13
```

showmount output (slide): `Export list for 10.10.1.9:` followed by `/home *`. The path `/home` is the **shared folder** (the export). The `*` means any client may mount it. That is a weak setting.

rpcinfo output (slide): a table with columns program, vers, proto, port, service.

Program	Service	Port in slide	Meaning
100000	portmapper	111	Tells clients which port each RPC service uses
100024	status	dynamic	NFS lock status
100005	mountd	dynamic	Handles mount requests
100003	nfs	2049	The NFS service itself
100021	nlockmgr	dynamic	NFS lock manager

The slide callout points to program `100003` with port `2049` and service `nfs` as the "open NFS port and an NFS service running on it".

How it works:

1. The attacker finds port 111 (portmapper) or 2049 (NFS) open.
2. `rpcinfo -p host` shows that NFS and mountd run.
3. `showmount -e host` lists the exported folders and who may mount them.
4. The attacker mounts a folder and reads or writes files (`mount -t nfs host:/home /mnt/x`, ADDED CONTEXT).

ADDED CONTEXT:

- `/etc/exports` is the file that defines what NFS shares and to whom. `root_squash` maps a remote root user to a harmless user. `no_root_squash` lets a remote root act as root on the share, which is dangerous.
- Nmap scripts: `nfs-showmount`, `nfs-ls`, `nfs-statfs`.
- `showmount -a` lists clients that have mounted shares. `showmount -d` lists mounted directories.

Real-world use: A tester sees `/home *` in the export list of a Linux file server. She mounts it, finds an SSH private key in one user folder, and logs in to another server. The report says: restrict exports to named hosts and block 2049.

AI angle: Prompt: "Show the commands to list NFS exports and RPC services on 10.10.1.9 and explain the output." AI will name `showmount -e` and `rpcinfo -p`. It may also suggest `nmap -sV -p 111,2049 --script nfs-showmount 10.10.1.9`.

Countermeasures and defense (slide):

- Implement proper permissions (read/write restricted to specific users) on exported file systems.
- Implement firewall rules to block NFS port 2049.
- Ensure proper configuration of files such as `/etc/smb.conf`, `/etc/exports`, and `/etc/hosts.allow` to protect data stored on servers.
- Log the requests to access system files on the NFS server.

EXAM FOCUS:

- Keywords: "exported directories", "centralization of data" -> NFS. "showmount -e" -> list exports. "rpcinfo -p" -> list RPC programs.
- Port: NFS 2049. Portmapper 111.
- Trap: `/etc/exports` is the main NFS file. The slide also names `/etc/smb.conf` (a Samba file) and `/etc/hosts.allow`. Learn all three.
- Look-alike: NFS (Unix sharing, 2049) versus SMB (Windows sharing, 445).

Memory trick: "show-mount -e = show Exports." "rpcinfo -p = print Programs." NFS = "Number 2049, Friendly Files."

3.10 SMTP Enumeration [slide 19, page 5]

What it is: SMTP (Simple Mail Transfer Protocol) moves email between mail servers. It listens on **TCP port 25**. The slide says SMTP provides three built-in commands:

Command	What it does (slide)
VRFY	Validates users
EXPN	Shows the actual delivery addresses of aliases and mailing lists
RCPT TO	Defines the recipients of a message

SMTP servers respond differently to VRFY, EXPN, and RCPT TO for valid and invalid users. From the difference, the attacker can **determine valid users** on the SMTP server. Attackers can interact with SMTP directly through the **telnet** prompt and collect a **list of valid users**.

Analogy: Calling a company switchboard and asking "Is Jonathan there?" (VRFY), "Who is on the sales team list?" (EXPN), or "Please deliver a note to Ryder" (RCPT TO). If the operator says "no such person", you learn who does not work there. If she says "OK", you learn who does.

How the three commands differ:

- **VRFY** checks one name. A valid user returns the full address, such as `Super-User <Jonathan@NMailserver>`.

- **EXPN** expands an alias or list. One request can show many real addresses at once. It leaks more than VRFY.
- **RCPT TO** is part of normal mail delivery. It is sent after `MAIL FROM`. It still works when admins disable VRFY and EXPN, so it is the most reliable method.

The three demos on the slide: The attacker connects with `telnet host 25`, says `HELO`, and then sends one command per name. The server banner on the slide is `220 NMailserver ESMTP Sendmail 8.9.3`.

Using the SMTP VRFY command:

```
$ telnet 192.168.1.1 25
Trying 192.168.1.1...
Connected to 192.168.1.1.
Escape character is '^]'.
220 NMailserver ESMTP Sendmail 8.9.3
HELO
501 HELO requires domain address
HELO x
250 NMailserver Hello [10.0.0.86], pleased to meet you
VRFY Jonathan
250 Super-User <Jonathan@NMailserver>
VRFY Smith
550 Smith... User unknown
```

Using the SMTP EXPN command:

```
EXPN Jonathan
250 Super-User <Jonathan@NMailserver>
EXPN Smith
550 Smith... User unknown
```

Using the SMTP RCPT TO command:

```
MAIL FROM:Jonathan
250 Jonathan... Sender ok
RCPT TO:Ryder
250 Ryder... Recipient ok
RCPT TO:Smith
550 Smith... User unknown
```

[UNCLEAR on page 5]: the server IP and the second valid name (read as "Ryder") are small on the slide. The samples above use 192.168.1.1 and the best reading of the names.

How to read the replies:

1. `220` means the server is ready (this line is the banner).
2. `501 HELO requires domain address` means the HELO line was empty. Send `HELO` plus any name.
3. `250` means success. For VRFY or RCPT TO it means the user exists.
4. `550 ... User unknown` means the user does not exist.

ADDED CONTEXT: Servers that hide users reply `252` (cannot verify, will accept) or `502` (command not implemented). On those servers use RCPT TO or a tool that tries all three methods.

Real-world use: A tester has a list of 300 guessed names. She connects to port 25 of the mail gateway and tries each with RCPT TO. 42 get `250`. Those 42 become the target list for a phishing test and a password spray test (trying one password on many accounts).

Tools and commands used here: telnet (or netcat), Nmap `smtp-enum-users`, Metasploit `smtp_enum`, smtp-user-enum, NetScanTools Pro (3.11).

AI angle: Prompt: "Write the telnet commands to test if the user admin exists on an SMTP server using VRFY, EXPN, and RCPT TO, and explain the reply codes." An attacker gets a ready script. A defender can ask AI to write a log rule that alerts on many VRFY or RCPT TO failures from one source.

Countermeasures and defense (slide, expanded in 3.22): Configure SMTP servers to:

- Exclude sensitive mail server and local host information from mail responses.
- Disable the **open relay** feature (an open relay forwards mail from anyone to anyone, so spammers abuse it).
- Limit the number of accepted connections from one source to prevent brute-force attacks.
- Provide limited information in error messages.

EXAM FOCUS:

- Keywords: "VRFY", "EXPN", "RCPT TO", "telnet to port 25", "valid users" -> SMTP enumeration.
- Reply keywords: `250` = user exists. `550 User unknown` = user does not exist.
- Trap: EXPN shows the delivery addresses of a list or alias. VRFY checks one user. RCPT TO is a normal delivery command, not a special enumeration command.
- Look-alike: VRFY versus EXPN. If the question says "mailing list" or "alias", choose EXPN.

Memory trick: "VRFY = Verify one. EXPN = Expand many. RCPT = Reach a recipient." Reply code: "250 = All good, 550 = No such person."

3.11 SMTP Enumeration Tools: Nmap, Metasploit, smtp-user-enum, NetScanTools Pro [slide 19 cont'd, page 5]

What it is: Typing telnet commands one at a time is slow. The slide shows four tools that automate the same VRFY, EXPN, and RCPT TO checks against a list of names.

Tool	Source on slide	What it shows
Nmap	nmap.org	`smtp-enum-users` script prints valid users under port 25
Metasploit	metasploit.com	Module `smtp_enum` prints "Found user" lines

Tool	Source on slide	What it shows
smtp-user-enum	pentestmonkey.net	Prints `host: user exists` for each hit
NetScanTools Pro	netscantools.com	GUI with an SMTP email generator and checker

Analogy: Instead of calling the switchboard 300 times by hand, you hand the operator a list and a machine dials for you.

What each screenshot shows:

- **Nmap:** a scan of port 25 with the NSE script. The result lists names found on the server, such as `root`, `admin`, `administrator`, `webadmin`, `sysadmin`, `netadmin`, `guest`, `user`, `web`, and `test`.
- **Metasploit:** the module `auxiliary/scanner/smtp/smtp_enum`, then `run`. The banner is `220 metasploitable.localdomain ESMTP Postfix (Ubuntu)`. The domain name is `localdomain`. Many lines read `192.168.1.56:25 - Found user: ...`.
- **smtp-user-enum:** a header with the scan information (mode, worker processes, usernames file, target count, target TCP port, query timeout) and then a line such as `192.168.1.56: administrator exists`. The scan ends with a result count and the number of queries per second.
- **NetScanTools Pro:** a Windows GUI with a tool list on the left and a results pane on the right that shows the SMTP dialog and the server replies.

[UNCLEAR on page 5]: the exact command lines in the first three screenshots are small. Section 5.4, 5.12, and 5.13 give the standard forms of each command.

How it works:

1. You give the tool a target host and a wordlist of usernames.
2. The tool opens port 25 and sends VRFY, EXPN, or RCPT TO for each name.
3. The tool reads each reply code.
4. It prints only the names that returned success.

Real-world use: A tester feeds a 10,000-name list to `smtp-user-enum` with `-M RCPT`. In two minutes she has 61 valid mailboxes. She hands the list to the phishing team and tells the client to disable user discovery on the gateway.

Tools and commands used here: The four tools above. ADDED CONTEXT: related Nmap scripts `smtp-commands` (lists supported commands) and `smtp-open-relay` (tests for open relay), and the Metasploit module `smtp_version`.

AI angle: Prompt: "Write a smtp-user-enum command that tests the RCPT method with users.txt against 10.10.1.30." Expected command: `smtp-user-enum -M RCPT -U users.txt -t 10.10.1.30`. AI can also write a short bash loop, but a ready tool is safer and faster.

Countermeasures and defense: Same as 3.10. Also rate-limit connections and log failed RCPT TO attempts.

EXAM FOCUS:

- Keywords: "smtp-user-enum" -> pentestmonkey tool for VRFY, EXPN, RCPT. "smtp-enum-users" -> Nmap NSE script. "smtp_enum" -> Metasploit module.
- Trap: Metasploit is a framework. Nmap is a scanner with scripts. Both can enumerate SMTP users. Pick based on the words in the question (module versus script).
- Look-alike: smtp-user-enum (tool) versus smtp-enum-users (Nmap script). Names are almost the same.

Memory trick: "smtp-user-enum = the standalone Enum tool. smtp-enum-users = the NSE script with Users at the end."

3.12 DNS Enumeration Using Zone Transfer [slide 21, page 6]

What it is: DNS (Domain Name System) turns names such as `www.example.com` into IP addresses. A **zone** is the set of DNS records that one name server manages for a domain. A **zone transfer** copies the whole zone from a primary DNS server to a secondary DNS server, so both stay in sync.

The slide says: if the target DNS server allows zone transfers, attackers can use this technique to obtain **DNS server names, hostnames, machine names, usernames, IP addresses, aliases**, and more assigned within a target domain. Attackers perform the zone transfer with tools such as **nslookup, dig, and DNSRecon**. If the transfer setting is enabled on the target name server, it returns the DNS information. If not, it returns an error that the transfer failed or was refused.

Analogy: A branch office asks head office for a full copy of the staff directory. If head office gives the copy to anyone who calls, a stranger gets the whole directory.

How it works:

1. Find the name servers of the target domain (query NS records).
2. Pick one name server.
3. Ask it for a full zone transfer (type **AXFR**). AXFR uses TCP port 53.
4. If the server allows it, it sends all records. If not, it says "Transfer failed" or "refused".
5. Read the records for hosts, mail servers, and internal names.

Linux demo with dig (slide):

```
dig ns www.certifiedhacker.com
dig @ns1.bluehost.com www.certifiedhacker.com axfr
```

- The first command asks for the **NS** records. The answer lists `ns1.bluehost.com` and `ns2.bluehost.com` as the name servers, and shows that `www` is a CNAME for `certifiedhacker.com`.
- The second command asks `ns1.bluehost.com` for the full zone. In the screenshot the result is `; Transfer failed.` That means this server refuses AXFR.

Windows demo with nslookup (slide):

```
C:\> nslookup
> set querytype=ns
> certifiedhacker.com
> server ns1.bluehost.com
> ls -d certifiedhacker.com
```

- `set querytype=ns` makes the next lookup return name servers.
- The lookup returns the name servers and a start of authority (SOA) block. The screenshot shows serial, refresh = 86400 (1 day), retry = 7200 (2 hours), expire = 1209600 (14 days), and default TTL = 180 (3 min).
- `server` points nslookup at one name server.
- `ls -d` asks for the whole zone. The screenshot ends with `*** Can't list domain ...: Server failed` and a message that the DNS server refused to transfer the zone to your computer. If this is incorrect, check the zone transfer security settings on the DNS server.

[UNCLEAR on page 6]: the exact domain typed after `ls -d` is small. The correct syntax uses the zone name (the domain), as shown above.

Real-world use: A tester finds that one old secondary DNS server of a client still allows AXFR. One `dig axfr` returns 380 records, including `vpn-test`, `db01`, and `hr-files`. These internal names are new targets. The client restricts transfers to the secondary server IPs.

Tools and commands used here: dig, nslookup, DNSRecon (`dnsrecon -d domain -t axfr`), Nmap `dns-zone-transfer` (ADDED CONTEXT).

AI angle: Prompt: "Show me how to test if example.com allows DNS zone transfers using dig, and how to read a refused result." An attacker gets steps in seconds. A defender can ask AI to write a script that tests every own domain for open AXFR once a week.

Countermeasures and defense (slide, expanded in 3.22): Audit DNS zones for weaknesses, allow zone transfers only to listed secondary servers, patch name servers, and keep resolvers reachable only from inside the network.

EXAM FOCUS:

- Keywords: "zone transfer", "AXFR", "dig ... axfr", "ls -d" -> DNS enumeration by zone transfer.
- Port: TCP 53 for zone transfers (UDP 53 is for normal queries).
- Trap: "Transfer failed" or "refused" means the server is configured correctly, not that the tool is broken.
- Look-alike: AXFR (full zone) versus IXFR (only changes since a serial number).

Memory trick: "AXFR = All X-Fer Records." The slide's three tools: "N-D-D = nslookup, dig, DNSRecon."

3.13 DNSSEC Zone Walking [slide 23, page 6]

What it is: DNSSEC (DNS Security Extensions) adds digital signatures to DNS records so that clients can trust the answers. To prove that a name does **not** exist, DNSSEC uses **NSEC** records. Each NSEC record names the next existing name in sorted order. If you follow the chain from one name to the next, you list every name in the zone. That is **zone walking**.

The slide says DNSSEC zone walking is a DNS enumeration technique in which an attacker attempts to **obtain internal records of the DNS server** if the DNS zone is **not properly configured**. Attackers use tools such as **LDNS** and **DNSRecon** to exploit this and obtain network information about a target domain, and then launch Internet-based attacks.

Analogy: A library catalog that says "after Apple comes Banana, after Banana comes Cherry". You never ask for the full list, but you walk the chain and rebuild it.

How it works:

1. The attacker asks for a name that does not exist.
2. The signed answer contains an NSEC record that says "no names between A and B".
3. The attacker asks about B and gets the next NSEC record.
4. He repeats until the chain returns to the start.
5. The collected names are the zone's hosts, even when AXFR is blocked.

ADDED CONTEXT: NSEC3 hashes the names so the chain does not show real names. It makes walking harder, but an attacker can still collect hashes and try a dictionary offline. Related record types: DNSKEY (public key), RRSIG (signature), DS (delegation signer, links parent and child zones).

Demos on the slide:

```
ldns-walk @8.8.8.8 nlnetlabs.nl
dnsrecon -d www.certifiedhacker.com -z
```

- **LDNS:** the screenshot shows the command followed by a long list of names with record types `NSEC` and `RRSIG`. A label calls the output the "Enumerated DNS record file". The target is the NLnet Labs zone, which is signed.
- **DNSRecon:** the `-z` flag asks for a DNSSEC zone walk. The screenshot first prints `DNSSEC is not configured for www.certifiedhacker.com`, then prints SOA, NS, MX, CNAME, A, and TXT records (including an SPF text value), says 0 SRV records were found, then "Performing NSEC Zone Walk" and "2 records found". Because that domain is not signed, the tool falls back to normal enumeration.

Real-world use: A tester finds that a signed zone uses NSEC (not NSEC3). `ldns-walk` returns 200 names, including `staging` and `test-api`, even though AXFR is refused. The client moves to NSEC3 and removes the old test hosts.

Tools and commands used here: ldns-walk (LDNS package), DNSRecon `-z`, Nmap `dns-nsec-enum` and `dns-nsec3-enum` (3.15).

AI angle: Prompt: "Explain DNSSEC zone walking in simple words and give the command to test if my zone leaks names through NSEC." AI gives a safe test plan. It should not be trusted for exact flags without a check.

Countermeasures and defense: Use NSEC3 with a salt and enough iterations, remove unused records, and audit DNS zones for weak spots (slide, 3.22).

EXAM FOCUS:

- Keywords: "NSEC", "walk the zone", "LDNS", "DNSRecon -z" -> DNSSEC zone walking.
- Trap: Zone walking is not a zone transfer. It works even when AXFR is refused.
- Trap: If DNSRecon says "DNSSEC is not configured", walking is not possible on that domain.
- Look-alike: NSEC (plain next-name chain) versus NSEC3 (hashed next-name chain).

Memory trick: "NSEC = Next SECure name. Walk = follow Next, Next, Next."

3.14 DNS Enumeration Using OWASP Amass [slide 24, page 7]

What it is: OWASP Amass is a DNS enumeration tool. The slide says it allows attackers to **map the target network** and **discover potential attack surfaces**. An **attack surface** is every place where an attacker could try to get in (every host, sub-domain, and IP range that is reachable). Amass collects names from many public sources, can ask DNS servers directly, can guess names from a wordlist, and stores what it finds in a graph database.

Analogy: A mapmaker who walks the whole town, asks the post office, reads public records, and knocks on doors of guessed addresses, then draws one map of every building the company owns.

Commands on the slide:

```
# Passive enumeration
amass enum -passive -d <Target Domain> -src

# Active enumeration with brute forcing
amass enum -active -d <Target Domain> -brute -w \
  /usr/share/wordlists/amass/all.txt

# Track or compare the last two enumeration scans
amass track -config /root/amass/config.ini -dir amass4owasp \
  -d <Target Domain> -last 2
```

Flag	Meaning
enum	Sub-command that runs DNS enumeration and network mapping
-passive	Use only public data sources, no direct DNS probing
-active	Also contact target systems (zone transfers, certificates)
-brute	Guess sub-domain names from a wordlist
-w	Path of the wordlist file
-d	Target domain
-src	Print which data source found each name

Flag	Meaning
track	Sub-command that compares past enumeration runs
-config	Path of the configuration file (API keys, settings)
-dir	Folder that holds the graph database
-last 2	Compare the last two enumerations

Demo on the slide: The screenshot runs Amass in Docker as `docker run caffix/amass enum -d certifiedhacker.com` (best reading). The output is a list of relationships between objects:

```
certifiedhacker.com (FQDN) --> ns_record --> ns1.bluehost.com (FQDN)
certifiedhacker.com (FQDN) --> mx_record --> mail.certifiedhacker.com
www.certifiedhacker.com (FQDN) --> a_record --> 162.241.216.11 (IPAddress)
162.241.216.0/24 (Netblock) --> contains --> 162.241.216.11 (IPAddress)
26337 (ASN) --> announces --> 162.241.216.0/24 (Netblock)
26337 (ASN) --> managed_by --> OIS - Oso Grande IP (RIROrganization)
```

How to read it: **FQDN** is a host name, **IPAddress** is an address, **Netblock** is an IP range, **ASN** (autonomous system number) is the ID of a network operator, and **RIROrganization** is the organization registered at a regional internet registry. The arrows show the record type or the link (`ns_record`, `mx_record`, `a_record`, `cname_record`, `contains`, `announces`, `managed_by`).

How it works:

1. You give Amass a root domain.
2. In passive mode it queries public sources (certificate logs, search engines, DNS datasets).
3. In active mode it also probes the target (zone transfer attempts, certificate grabbing, brute force).
4. It resolves names to IPs, groups them into netblocks and ASNs, and saves the graph.
5. `track` compares two runs and shows new or removed names.

Real-world use: A security team runs `amass enum -passive` every week on their own domain. `track` shows a new name `dev-backup.example.com` that nobody told them about. They find an old test server and shut it down.

Tools and commands used here: Amass. Related tools: Sublist3r, subfinder, and DNSRecon (Module 02).

AI angle: Prompt: "Write an Amass command for passive enumeration of example.com that saves results to a text file." AI returns `amass enum -passive -d example.com -o out.txt`. Check the Amass version, because flags change between releases.

> **ADDED CONTEXT:** Newer Amass v4 releases changed sub-commands and deprecated some flags such as `-passive` (verify). The exam follows the slide syntax shown above.

Countermeasures and defense: Audit your own DNS zones, remove stale records, patch name servers (slide, 3.22), and use Amass yourself to see what outsiders see.

EXAM FOCUS:

- Keywords: "OWASP", "map the target network", "attack surface", "-brute -w" -> Amass.
- Flag recall: `-passive` (public sources), `-active` (contacts target), `-brute -w` (wordlist guessing), `-src` (data source), `track ... -last 2` (compare last two scans).
- Trap: Passive does not touch the target. Active and brute force do.
- Look-alike: Amass (attack surface mapping with a graph) versus subfinder (passive sub-domain list only).

Memory trick: "Amass = A MAp of the Surface Space." Three modes: Passive = Peek, Active = Approach, Brute = Bang on the door.

3.15 DNS and DNSSEC Enumeration Using Nmap [slide 25, page 7]

What it is: Nmap can enumerate DNS and DNSSEC with NSE scripts. **NSE** (Nmap Scripting Engine) is the part of Nmap that runs small scripts for extra tasks.

- **DNS enumeration (slide):** attackers use Nmap for scanning domains and obtaining a list of **subdomains, records, IP addresses**, and other valuable information from the target host.
- **DNSSEC enumeration (slide):** attackers enumerate DNSSEC using Nmap with the scripts **dns-nsec-enum.nse** or **dns-nsec3-enum.nse** to obtain information related to domains and their sub-domains.

Analogy: Nmap is a Swiss army knife. The NSE scripts are the extra blades: one for guessing sub-domains, one for walking NSEC chains.

Commands (best reading and standard forms):

```
nmap --script dns-brute certifiedhacker.com
nmap -sSU -p 53 --script dns-nsec-enum \
  --script-args dns-nsec-enum.domains=example.com ns1.example.com
nmap -sU -p 53 --script dns-nsec3-enum \
  --script-args dns-nsec3-enum.domains=example.com ns1.example.com
```

[UNCLEAR on page 7]: the two Nmap screenshots are small. The first lists sub-domains and addresses (best reading: `dns-brute`). The second runs a DNSSEC script. The forms above are the standard NSE usage (verify against `nmap.org/nsedoc`).

Script	What it does
dns-brute	Guesses sub-domain names from a built-in list
dns-zone-transfer	Tries an AXFR zone transfer (ADDED CONTEXT)
dns-nsec-enum	Walks NSEC records to list names
dns-nsec3-enum	Collects NSEC3 hashed names to attack offline
dns-srv-enum	Lists SRV records for common services (ADDED CONTEXT)

Other DNS enumeration tools (slide, all on GitHub): Knock, Subfinder, Raccoon, Turbolist3r.

- **Knock (Knockpy):** guesses sub-domains from a wordlist.
- **Subfinder:** passive sub-domain discovery from public sources.
- **Raccoon:** an all-in-one recon tool that includes DNS work.
- **Turbolist3r:** a sub-domain enumeration tool based on Sublist3r (verify).

How it works:

1. Choose the NSE script that matches the job (guess names, walk NSEC, collect NSEC3).
2. Give the script the domain as a script argument.
3. Nmap sends DNS queries to the name server (UDP 53, sometimes TCP 53).
4. The script prints names, IPs, and records.

Real-world use: A tester has no zone transfer rights. She runs `dns-brute` and finds `vpn`, `git`, and `jenkins` hosts that did not appear in search engines.

AI angle: Prompt: "Which Nmap scripts enumerate DNS sub-domains and DNSSEC NSEC records? Give one command for each." This is a fast way to recall script names. Check each name in the Nmap script list.

Countermeasures and defense: Same as 3.12 and 3.13. Use NSEC3, restrict zone transfers, and remove stale records.

EXAM FOCUS:

- Keywords: "dns-nsec-enum.nse", "dns-nsec3-enum.nse" -> DNSSEC enumeration with Nmap.
- Keywords: "Knock, Subfinder, Raccoon, Turbolist3r" -> DNS enumeration tool list on this slide.
- Trap: These scripts need a DNSSEC-signed zone. A normal unsigned zone returns nothing useful.
- Look-alike: dns-nsec-enum (NSEC, plain names) versus dns-nsec3-enum (NSEC3, hashed names).

Memory trick: "nsec = names in the open. nsec3 = names in a bag (hashed)."

3.16 IPsec Enumeration [slide 29, page 8]

What it is: IPsec (Internet Protocol Security) is a set of protocols that encrypts and authenticates IP traffic. Most **VPNs** (virtual private networks) use it. The slide says most IPsec-based VPNs use **ISAKMP**, a part of **IKE**, to establish, negotiate, modify, and delete **Security Associations (SA)** and cryptographic keys in a VPN environment.

- **IKE** (Internet Key Exchange): the protocol that sets up the VPN and agrees on keys.
- **ISAKMP** (Internet Security Association and Key Management Protocol): the framework that carries IKE messages.

- **SA** (Security Association): the set of agreed rules for one VPN tunnel: encryption algorithm, hash algorithm, authentication type, key exchange group, and lifetime.

Analogy: Two people meet, agree on a secret language, a code word, and how long the code lasts, and then talk. The SA is that written agreement.

What the attacker does (slide):

- A simple scan for ISAKMP at **UDP port 500** can show that a VPN gateway is present.
- The attacker then probes further with a tool such as **ike-scan** to enumerate sensitive information: the **encryption and hashing algorithm**, the **authentication type**, the **key distribution algorithm**, and the **SA LifeDuration**.
- The slide adds an AI idea: an attacker can use ChatGPT or another generative AI tool with a prompt such as **"Perform IPsec enumeration on target IP 10.10.1.22 with nmap"**.

Demos on the slide (best reading):

```
nmap -sU -p 500 10.10.1.22
ike-scan -M 10.10.1.22
sgpt --shell "Perform IPsec enumeration on target IP 10.10.1.22 with nmap"
```

- The Nmap scan shows `500/udp open isakmp`. That is a VPN gateway sign.
- The ike-scan screenshot shows `Notify message 14 (NO-PROPOSAL-CHOSEN)`. The gateway answered, so IKE is alive, but it rejected the sample proposal the tool sent.
- The ShellGPT screenshot shows the prompt, a generated Nmap command, and the option to execute it. The result again shows UDP 500 open (`isakmp`).

[UNCLEAR on page 8]: the exact flags in the ike-scan and generated Nmap commands are small. The forms above are the likely ones.

How it works:

1. The attacker scans UDP 500 (and UDP 4500, ADDED CONTEXT) on a range.
2. An open `isakmp` port means a VPN gateway.
3. ike-scan sends IKE proposals and reads the reply.
4. A reply that holds an SA shows the accepted encryption, hash, authentication, DH group, and lifetime. A notify reply proves the gateway exists even if it rejects the proposal.
5. The attacker judges how weak the VPN is (old algorithms such as DES or MD5, or a pre-shared key in aggressive mode) and plans the next step.

ADDED CONTEXT:

- **Main mode** hides the identity. **Aggressive mode** is faster but sends the group ID in clear text and, with a pre-shared key (PSK), returns a hash an attacker can crack offline (`ike-scan -A` then `psk-crack`).
- **UDP 4500** is NAT-T (NAT traversal). **ESP** is IP protocol 50. **AH** is IP protocol 51.
- Output words: `1 returned handshake` means the gateway accepted a proposal. `1 returned notify` means it replied with an error.

Real-world use: A tester scans a client's public range and finds UDP 500 open on one address. ike-scan shows 3DES, SHA1, Diffie-Hellman group 2, and a PSK. She reports that the VPN uses weak crypto and recommends AES, SHA-256, and certificates.

Tools and commands used here: Nmap, ike-scan, ShellGPT (sgpt).

AI angle: The slide shows the exact prompt: "Perform IPsec enumeration on target IP 10.10.1.22 with nmap". A generative AI tool turns it into an Nmap command. Risk: AI may pick wrong flags (for example a TCP scan on a UDP port). Read before you run.

Countermeasures and defense: The slides give no IPsec fix. ADDED CONTEXT: use strong algorithms, disable aggressive mode, use certificates or long PSKs, and allow UDP 500 and 4500 only from known peers.

EXAM FOCUS:

- Keywords: "ISAKMP", "UDP port 500", "ike-scan", "SA LifeDuration" -> IPsec enumeration.
- What ike-scan returns: encryption and hashing algorithm, authentication type, key distribution algorithm, SA LifeDuration.
- Trap: ISAKMP is UDP 500, not TCP.
- Look-alike: IKE (negotiates keys) versus ESP (encrypts the data).

Memory trick: "500 = Five-hundred, Five Zero Zero, VPN Gateway Zone." ike-scan returns the "A-A-K-L": Algorithms, Authentication, Key group, Lifetime.

3.17 VoIP Enumeration [slide 30, page 9]

What it is: VoIP (Voice over IP) carries phone calls over an IP network. The slide says VoIP uses the **Session Initiation Protocol (SIP)** to enable voice and video calls over an IP network. SIP generally uses **UDP/TCP ports 2000, 2001, 5060, and 5061**.

Analogy: SIP is the switchboard operator who connects calls. VoIP enumeration is asking the operator for the list of every desk phone and extension.

What enumeration gives (slide): VoIP gateways and servers, IP-PBX systems (a **PBX** is a private phone exchange), client software (softphones, which are phone apps) and VoIP phones, user-agent IP addresses, and user extensions.

Attacks this enables (slide):

Attack	Meaning
DoS	Flood the phone system so calls fail
Session hijacking	Take over a live call
Caller ID spoofing	Fake the number shown on the phone
Eavesdropping	Listen to calls
SPIT	Spamming over Internet Telephony, junk calls
Vishing	VoIP phishing, tricking people over a call

Demos on the slide:

```
svmap 151.50.106.225
```

- svmap (from the SIPVicious suite) scans for SIP devices. The output is a table with the columns **SIP Device** and **User Agent**. The row shows `151.50.106.225:5060` with the user agent `DLink VoIP Stack`.
- The Metasploit screenshot loads a SIP scanner module, sets `RHOSTS` to a /24 range, and runs it. The module sends **SIP OPTIONS** requests to every address. Replies show `SIP/2.0 200 OK`, a `User-Agent` such as `Grandstream HT503`, and an `Allow` list (`INVITE, ACK, OPTIONS, CANCEL, BYE, SUBSCRIBE, NOTIFY, INFO, REFER, UPDATE, MESSAGE`). It ends with `Scanned 256 of 256 hosts (100% complete)`.

[UNCLEAR on page 9]: the module name is small. The best reading is `auxiliary/scanner/sip/options`. Details are in 5.13 and 5.21.

How it works:

1. The attacker scans for SIP on UDP 5060 (and TCP 5060, 5061).
2. A SIP OPTIONS request asks "what do you support?".
3. The device replies with its model (user agent) and the SIP methods it allows.
4. Other tools then guess extensions and passwords (ADDED CONTEXT: svwar finds extensions, svcrack guesses passwords).

Real-world use: A tester scans a hotel's phone VLAN and finds 200 phones. The user-agent list shows that 40 phones run a very old firmware. She reports the list and the extension range.

AI angle: Prompt: "Write a command to find SIP devices on 192.168.0.0/24 and list their user agents." AI will propose svmap or an Nmap `sip-methods` scan. For defense, ask AI to draft a SIP firewall rule set.

Countermeasures and defense: The slides give no VoIP fix. ADDED CONTEXT: put phones on a separate VLAN, use SIP over TLS (5061) and SRTP for media, change default phone passwords, and block SIP from the internet.

EXAM FOCUS:

- Keywords: "Session Initiation Protocol", "5060", "IP-PBX", "extensions" -> VoIP enumeration.
- Ports to memorize from the slide: 2000, 2001, 5060, 5061.
- Trap: 5060 is SIP in clear text. 5061 is SIP over TLS (verify for the slide's 2000 and 2001, which are listed there without names).
- Look-alike: SPIT (spam calls) versus vishing (voice phishing). Both are VoIP attacks.

Memory trick: "SIP, 5-0-6-0. Sip a drink, call a friend." Attacks: "D-S-C-E-S-V" = DoS, Session hijack, Caller ID, Eavesdrop, SPIT, Vishing.

3.18 RPC Enumeration [slide 31, page 9]

What it is: RPC (Remote Procedure Call) lets a program on one computer run a function on another computer as if the function were local. The slide says RPC allows clients and servers to communicate in **distributed client/server programs**. Enumerating **RPC endpoints** enables attackers to identify any **vulnerable services** on these service ports.

An **endpoint** is the port and address where an RPC service listens. An **endpoint mapper** (or portmapper) is a service that tells clients which port a given RPC service uses.

Analogy: A hotel front desk. You ask "which room is the spa in?" and the desk tells you. RPC enumeration is asking the desk for the full room list.

Screenshots on the slide: Two tools are shown. The left one is a Windows GUI (the URL under it is netscantools.com) with an "Open RPC Ports" style view. The right one is a scanner window with long text output. [UNCLEAR on page 9]: the name of the second tool is not readable.

How it works:

1. The attacker finds the endpoint mapper port open (TCP/UDP 135 on Windows, TCP/UDP 111 on Unix).
2. He asks the mapper which RPC programs are registered.
3. The mapper replies with program names, versions, protocols, and ports.
4. The attacker checks each service for known weaknesses.

ADDED CONTEXT:

- Windows: port 135 is the Microsoft RPC endpoint mapper. Tools: `rpcdump` (Impacket), `rpcclient` (Samba), Nmap `msrpc-enum`.
- Unix: port 111 is the portmapper (rpcbind). Tool: `rpcinfo -p host` (see 3.9 and 5.10).
- `rpcclient -U "" host` opens a session with an empty username. Commands such as `enumdomusers` and `srvinfo` then list accounts and server data.

Real-world use: A tester finds port 135 open on a Windows server and dumps the endpoints. One listed service is an old print spooler interface. She flags it for patching.

Tools and commands used here: NetScanTools Pro, rpcinfo, rpcclient, rpcdump, Nmap.

AI angle: Prompt: "List the commands to enumerate RPC services on 10.10.1.22 for Windows and for Linux." AI returns the commands above. Verify each against your tool versions.

Countermeasures and defense: The slides give no RPC fix. ADDED CONTEXT: block ports 135 and 111 from untrusted networks, disable unneeded RPC services, and patch.

EXAM FOCUS:

- Keywords: "distributed client/server programs", "RPC endpoints", "vulnerable services on these service ports" -> RPC enumeration.

- Trap: 135 (Microsoft RPC) versus 111 (Unix portmapper).
- Look-alike: RPC (remote function calls) versus NFS (file sharing built on top of RPC).

Memory trick: "RPC = Remote Program Calls. 135 = Windows (one-three-five, Windows alive). 111 = Unix (all ones, one Unix)."

3.19 Unix/Linux User Enumeration [slide 32, page 10]

What it is: Unix and Linux have small built-in commands that report who is logged in. The slide lists three: **rusers**, **rwho**, and **finger**. They work well on a local network where the "r-services" (remote services) are still on.

Command	What it shows (slide)
rusers	Users logged on to remote or local network machines
rwho	Users logged on to hosts on the local network
finger	Details about system users

Syntax from the slide (code block because of pipes):

```
/usr/bin/rusers [-a] [-l] [-u| -h| -i] [Host ...]
rwho [ -a]
finger [-l] [-m] [-p] [-s] [user ...] [user@host ...]
```

What finger returns (slide): login name, real name, terminal name, idle time, login time, office location, and office phone numbers.

Demo on the slide:

```
ubuntu@ubuntu-Virtual-Machine:~$ finger
Login   Name    Tty   Idle  Login Time   Office  Office Phone
ubuntu  Ubuntu  *:1         Mar 12 03:23 (:1)
ubuntu@ubuntu-Virtual-Machine:~$ finger ubuntu
Login: ubuntu                     Name: Ubuntu
Directory: /home/ubuntu           Shell: /bin/bash
On since Tue Mar 12 03:23 (EDT) on :1 from :1 (messages off)
No mail.
No Plan.
```

- `finger` with no name lists the logged-in users in a table.
- `finger ubuntu` gives a long report for one user: the home directory `/home/ubuntu`, the shell `/bin/bash`, when the user logged in, mail status, and the `.plan` file text ("No Plan" means the file is empty).

Analogy: The visitor board at a building lobby. rusers and rwho read the board for the whole building. finger reads one person's full card.

How it works:

1. The attacker reaches a Unix host that runs the finger service (TCP 79) or the rwho/rusers daemons.
2. He runs `finger @host` or `finger user@host`, `rusers -l host`, or `rwho`.
3. The host replies with login names, real names, shells, and login times.

4. He uses the login names for password guessing and learns who is active.

ADDED CONTEXT: `rwho` depends on the `rwhod` daemon, which broadcasts on the local network (UDP 513). `rusers` uses RPC. `finger` uses TCP 79. All three are old and are normally off on modern systems.

Real-world use: On an internal test of a lab network, a tester runs `rusers -l` and sees that `admin1` has been logged in for 6 days on a build server. She tests that account first.

Tools and commands used here: rusers, rwho, finger.

AI angle: Prompt: "Which Linux commands list logged-in users on remote hosts, and which are obsolete?" AI explains rusers, rwho, finger and also suggests `who` and `w` for local checks.

Countermeasures and defense: The slide set gives none for this topic. ADDED CONTEXT: disable finger, rwhod, and rusersd, block TCP 79 and UDP 513, and use SSH-based tools instead.

EXAM FOCUS:

- Keywords: "login name, real name, terminal name, idle time, office phone" -> finger. "logged on to remote machines" -> rusers. "hosts on the local network" -> rwho.
- Flag recall: rusers `-a` (all machines), `-l` (long), `-u`, `-h`, `-i` (sort options, ADDED CONTEXT); rwho `-a`; finger `-l`, `-m`, `-p`, `-s`.
- Trap: finger gives the most personal detail (names, phones). rwho gives the least.
- Look-alike: rusers (remote users via RPC) versus rwho (broadcast list on the local network).

Memory trick: "r-USERS = remote USERS. r-WHO = local WHO. FINGER = point at one person."

3.20 SMB Enumeration (with AI) [slide 33, page 11]

What it is: SMB (Server Message Block) is the Windows protocol for file, printer, and pipe sharing. Modern SMB runs directly on **TCP port 445**. The slide says attackers use SMB enumeration tools such as **Nmap, SMBMap, enum4linux, and nullinux** to perform a directed scan on the SMB service running on port 445. SMB enumeration helps attackers perform **OS banner grabbing** on the target (learning the operating system and version from what the service reports).

Analogy: Knocking on the file room door and asking "who are you, what system do you run, and which cabinets can I see?".

Screenshot on the slide: a terminal scan with two labels: **"Open port 445"** and **"SMB details"**. The output lists the open port and, below it, SMB script results (computer name, OS version, workgroup, and the like).

SMB enumeration with AI (slide): An attacker can also use an AI-powered tool such as ChatGPT or another generative AI with a prompt such as:

```
Scan the target IP 10.10.1.22 for the port using SMB with nmap
```

The ShellGPT screenshot turns the prompt into an Nmap command, runs it, and shows port 445 open with SMB host details. [UNCLEAR on page 11]: the generated command is small. A typical result is `nmap -p 445 --script smb-os-discovery 10.10.1.22`.

How it works:

1. The attacker finds TCP 445 (or 139) open.
2. He runs an SMB enumeration tool against it.
3. The tool negotiates an SMB session, often with a **null session** (no username and no password) or a guest login.
4. The server reports its OS, domain, shares, and sometimes users and password policy.
5. The attacker uses the data to pick passwords to guess or an exploit to run.

ADDED CONTEXT:

Tool	What it does	Example
Nmap	NSE scripts for OS, shares, users	nmap -p 445 --script smb-os-discovery host
SMBMap	Lists shares and their permissions	smbmap -H host
enum4linux	Pulls users, shares, groups, policy	enum4linux -a host
nullinux	Uses null sessions to list users	nullinux host
smbclient	Connects to a share like an FTP client	smbclient -L host -N

- A **null session** is an SMB connection made with an empty username and password to the hidden `IPC$` share. On old or badly set up Windows systems it can reveal user names and shares.
- **RID cycling** means asking for account numbers one by one (RID 500 is the built-in Administrator, 501 is Guest, normal users start at 1000) to find every account.
- Useful Nmap scripts: `smb-os-discovery`, `smb-enum-shares`, `smb-enum-users`, `smb-security-mode`, `smb-protocols`.

Real-world use: A tester finds 445 open on a file server. `enum4linux -a` returns the domain name, 35 user names, and the password policy (minimum length 6). She reports the weak policy and the null session.

Tools and commands used here: Nmap, SMBMap, enum4linux, nullinux, and ShellGPT.

AI angle: Besides the slide prompt, a defender can ask: "Review this enum4linux output and list the five riskiest findings." AI is good at sorting large dumps. A real risk is pasting client data into a public AI service.

Countermeasures and defense (slide, 3.22): Disable SMB on web and DNS servers and internet-facing servers, disable TCP 139 and 445, and restrict anonymous access with `RestrictNullSessAccess` in the Windows Registry.

EXAM FOCUS:

- Keywords: "port 445", "OS banner grabbing", "SMBMap", "enum4linux", "nullinux" -> SMB enumeration.
- AI keyword: the prompt "Scan the target IP ... for the port using SMB with nmap" is the slide's SMB-with-AI example.
- Trap: 445 is SMB over TCP directly. 139 is SMB over NetBIOS.
- Look-alike: SMB (Windows sharing, 445) versus NFS (Unix sharing, 2049). Samba is the Linux software that speaks SMB.

Memory trick: "SMB = 4-4-5, Share My Box." Tools: "S-E-N-N" = SMBMap, Enum4linux, Nullinux, Nmap.

3.21 Enumeration Countermeasures: SNMP, LDAP, NFS [slide 38, page 11]

What it is: The slide splits the first set of fixes by service. A **countermeasure** is an action that reduces risk.

SNMP

- Remove the SNMP agent or turn off the SNMP service.
- If turning SNMP off is not an option, change the default community string names.
- Upgrade to **SNMPv3**, which encrypts passwords and messages.
- Implement the Group Policy security option called **"Additional restrictions for anonymous connections"**.

LDAP

- By default LDAP traffic is transmitted unsecured. Use **SSL or STARTTLS** technology to encrypt the traffic.
- Select a **username different from your email address** and enable **account lockout**.
- Use **NT LAN Manager (NTLM), Kerberos**, or any basic authentication mechanism to limit access to legitimate users.

NFS

- Implement **proper permissions** (read/write must be restricted to specific users) on exported file systems.
- Implement **firewall rules** to block **NFS port 2049**.
- Ensure proper configuration of files such as **/etc/smb.conf, /etc/exports, and /etc/hosts.allow** to protect the data stored in servers.
- **Log the requests** to access system files on the NFS server.

Analogy: Three different doors, three different locks: a password change for SNMP, encryption for LDAP, a closed gate for NFS.

How to apply it:

1. Find which services answer (a scan result).

2. Match each service to its fix above.
3. Apply the fix and scan again to prove the answer is gone.

AI angle: Prompt: "Give me a hardening checklist for SNMP, LDAP, and NFS on a Linux and Windows network." AI produces a checklist. Always compare it with the slide list because the exam uses the slide wording.

EXAM FOCUS:

- "Upgrade to SNMPv3" and "change default community strings" -> SNMP fixes.
- "SSL or STARTTLS" and "account lockout" -> LDAP fixes.
- "Block port 2049" and "/etc/exports" -> NFS fixes.
- Trap: Kerberos and NTLM are listed under LDAP as authentication choices. They are not encryption.
- Look-alike: SNMPv3 (adds encryption and authentication) versus changing the community string (still clear text in v1 and v2c).

Memory trick: One word each: SNMP = "v3", LDAP = "TLS", NFS = "2049".

3.22 Enumeration Countermeasures (Cont'd): SMTP, SMB, DNS [slide 39, page 12]

What it is: The second set of fixes covers mail, Windows sharing, and DNS.

SMTP: configure SMTP servers to

- Exclude sensitive mail server and local host information in mail responses.
- Disable the **open relay** feature.
- Limit the number of accepted connections from a source to prevent brute-force attacks.
- Provide limited information in error messages.

SMB

- Disable the SMB protocol on **web and DNS servers**.
- Disable SMB on **internet-facing servers**.
- Disable ports **TCP 139 and TCP 445** used by the SMB protocol.
- Restrict anonymous access through the **RestrictNullSessAccess** parameter in the **Windows Registry**.

DNS

- Ensure the **resolver can be accessed only by hosts inside the network**.
- Ensure that request packets exiting the network use **random ports**.
- **Audit DNS zones** to identify vulnerabilities in domains and subdomains.
- **Update and patch name servers** with the most recent versions of software.

Notes:

- A **resolver** is the DNS server that answers lookups for clients. Keeping it internal stops outsiders from using it for probing or cache attacks.

- **Random source ports** make it harder to forge DNS replies (cache poisoning).
- `RestrictNullSessAccess` is a Registry value of the Server service. When it is 1, null session access is limited. [ADDED CONTEXT: it sits under `HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters` (verify).]

ADDED CONTEXT: Also restrict AXFR to named secondary servers and use NSEC3 on signed zones (3.12 and 3.13).

How to apply it: Same three steps as 3.21: map each open service to its fix, apply, and rescan.

AI angle: Prompt: "Write a short audit script that checks if SMB ports 139 and 445 are open on a list of servers." AI can draft a Nmap or PowerShell script. A human must review it first.

EXAM FOCUS:

- "Open relay" -> SMTP. "RestrictNullSessAccess" or "ports 139 and 445" -> SMB. "Random ports" or "resolver inside the network" -> DNS.
- Trap: SMB ports are TCP 139 and 445 (both are listed). NFS is 2049.
- Look-alike: disabling the SMB protocol (slide) versus blocking the port at the firewall. Both appear as correct, so choose the one the question names.

Memory trick: "SMTP: no relay. SMB: no null, no 139 or 445. DNS: inside resolver, random ports, audit, patch."

3.23 AI-Assisted Enumeration: Prompts, ShellGPT, and Limits (ADDED CONTEXT)

> **ADDED CONTEXT:** This topic is not a separate slide. It joins the two AI slides (IPsec and SMB) with the CEH v13 AI theme, so that you can answer AI questions for any service in this module.

What it is: A generative AI tool (an LLM, large language model, such as ChatGPT) can turn plain English into an enumeration command, explain command output, and write short scripts. **ShellGPT** (`sgpt`) is a command-line program that sends your prompt to an LLM and, with `--shell`, returns a ready shell command that you can execute, describe, or abort.

Analogy: A fast junior assistant who knows many commands by heart but sometimes misremembers a flag. You still have to check the work before you sign it.

Prompts from the slides and matching prompts for other services:

Service	Example prompt	Likely command idea
IPsec (slide)	Perform IPsec enumeration on target IP 10.10.1.22 with nmap	nmap -sU -p 500
SMB (slide)	Scan the target IP 10.10.1.22 for the port using SMB with nmap	nmap -p 445 scripts
SNMP	List SNMP processes on 10.10.1.22 with nmap	nmap -sU -p 161 snmp scripts

Service	Example prompt	Likely command idea
SMTP	Find valid SMTP users on 10.10.1.30	nmap smtp-enum-users
NFS	Show NFS exports of 10.10.1.9	showmount -e
DNS	Test whether example.com allows a zone transfer	dig axfr

How it works:

1. The user writes a goal in plain words (include the target and the tool name).
2. ShellGPT sends the prompt to the model.
3. The model replies with a command.
4. The user reads it, then chooses Execute, Describe, or Abort.
5. The output goes back to the AI to be summarized or put in a report.

How AI helps the attacker: faster command building, quick explanation of unknown output, script writing, and report drafts. Malicious tools in the same family (for example WormGPT and FraudGPT) have no safety filters and write attack code on request.

How AI helps the defender: it summarizes scan results, finds risky settings in a large dump, writes detection rules for repeated VRFY or AXFR attempts, and drafts hardening checklists.

Limits and risks:

- **Wrong or invented flags.** The model may mix a TCP flag into a UDP scan. Test and read the man page.
- **Data leak.** Pasting real client output into a public AI service can break confidentiality.
- **Scope.** AI does not check authorization. The tester must stay inside the signed scope.
- **Old knowledge.** The model may suggest tools or flags that no longer exist.

Real-world use: A tester types the SMB prompt into ShellGPT, reviews the command, runs it on the lab target, and pastes the output (with client names removed) into a chat to get a three-line summary for the report.

Countermeasures and defense: Treat enumeration the same way whether a human or an AI built the command. Block the ports, patch, log queries, and train staff not to paste sensitive data into public AI tools.

EXAM FOCUS:

- Keywords: "ChatGPT", "ShellGPT", "appropriate prompt", "generative AI" with "enumeration" -> AI-assisted enumeration.
- The best answer on AI questions is usually "AI speeds up the task, but the tester must verify the output and stay in scope".
- Trap: AI does not replace the tool. The AI writes the Nmap command. Nmap still does the scan.
- Look-alike: ShellGPT (command-line AI helper) versus ChatGPT (chat interface).

Memory trick: "Prompt, Produce, Proof-read, Proceed." Four P's, in that order.

4. Tool Encyclopedia

All tools below come from your slides unless the cell says ADDED. "Phase" is the hacking phase where the tool is mainly used. Enumeration happens between scanning and gaining access.

4.1 NetBIOS, Windows, and SMB Tools

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
nbtstat	Shows NetBIOS name table of a host	Windows command	Enumeration	"NetBIOS name table"
NetBIOS Enumerator	Reads NetBIOS data for an IP range	Windows GUI	Enumeration	"specify an IP range"
Nmap	Port scanner with NSE scripts	Cross-platform CLI	Scanning and enumeration	"NSE script"
Global Network Inventory	Audits hosts and collects details	Windows GUI	Enumeration	"network inventory"
Advanced IP Scanner	Fast LAN scanner with shares list	Windows GUI	Scanning and enumeration	"LAN scanner"
Hyena	Manages and lists users, shares, domains	Windows GUI	Enumeration	"Hyena"
net view	Lists shares of a host or domain	Windows command	Enumeration	"shared resources"
SMBMap	Lists SMB shares and permissions	Linux CLI	Enumeration	"SMBMap"
enum4linux	Pulls users, shares, groups, policy	Linux CLI	Enumeration	"enum4linux"
nullinux	Enumerates users with null sessions	Linux CLI	Enumeration	"nullinux"
smbclient (ADDED)	FTP-like client for SMB shares	Linux CLI	Enumeration	"list shares from Linux"
nbtscan (ADDED)	Fast NetBIOS scanner	Linux CLI	Enumeration	"NetBIOS scan Linux"
Winfingerprint (ADDED)	Scans Windows hosts for users and shares	Windows GUI	Enumeration	"Windows fingerprint"
DumpSec (ADDED)	Dumps share and user permissions	Windows GUI	Enumeration	"permissions dump"

4.2 SNMP, LDAP, NTP, and NFS Tools

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
snmpwalk	Walks the whole MIB of an SNMP agent	Linux CLI	Enumeration	"snmpwalk -v1 -c public"

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
snmp-check	Prints SNMP data in a readable report	Linux CLI	Enumeration	"snmp-check"
SoftPerfect Network Scanner	Scans hosts, shares, SNMP data	Windows GUI	Scanning and enumeration	"SoftPerfect"
Network Performance Monitor	Monitors devices with SNMP	SolarWinds product	Enumeration	"SolarWinds NPM"
OpUtils	Network tools suite with SNMP views	ManageEngine product	Enumeration	"OpUtils"
onesixtyone (ADDED)	Guesses SNMP community strings fast	Linux CLI	Enumeration	"community string brute force"
ldapsearch	Queries an LDAP directory	Linux CLI	Enumeration	"ldapsearch"
Softerra LDAP Administrator	Browses and edits LDAP directories	Windows GUI	Enumeration	"Softerra"
AD Explorer	Browses Active Directory	Sysinternals GUI	Enumeration	"AD Explorer"
LDAP Admin Tool	Browses LDAP directories	Windows GUI	Enumeration	"LDAP Admin Tool"
ntptrace	Follows NTP servers to the primary source	Unix CLI	Enumeration	"chain of NTP servers"
ntpdc	Queries and monitors the ntpd daemon	Unix CLI	Enumeration	"monitors operation of ntpd"
ntpq	Queries ntpd and checks performance	Unix CLI	Enumeration	"determines performance"
showmount	Lists NFS exports of a server	Unix CLI	Enumeration	"showmount -e"
rpcinfo	Lists RPC programs and ports	Unix CLI	Enumeration	"rpcinfo -p"
RPCScan	Scans RPC and NFS services	Python tool	Enumeration	"RPCScan"
SuperEnum	Script that runs many enum tools	Bash script	Enumeration	"SuperEnum"

4.3 SMTP and DNS Tools

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
telnet (ADDED role)	Opens port 25 for manual VRFY and EXPN	Cross-platform CLI	Enumeration	"telnet to port 25"
smtp-user-enum	Tests many names with VRFY, EXPN, RCPT	Perl CLI (pentestmonkey)	Enumeration	"smtp-user-enum"
Metasploit smtp_enum	Module that finds valid SMTP users	Framework module	Enumeration	"auxiliary scanner smtp"

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
NetScanTools Pro	Suite with SMTP and RPC checks	Windows GUI	Enumeration	"NetScanTools"
nslookup	Queries DNS, tries zone transfer	Windows and Linux CLI	Enumeration	"ls -d"
dig	Queries DNS in detail	Linux CLI	Enumeration	"dig axfr"
DNSRecon	DNS recon: AXFR, brute, zone walk	Python CLI	Enumeration	"dnsrecon -z"
LDNS (ldns-walk)	Walks NSEC records	Library and CLI	Enumeration	"ldns-walk"
OWASP Amass	Maps attack surface of a domain	Go CLI	Enumeration	"Amass enum -brute"
Knock	Guesses sub-domains from a wordlist	Python tool	Enumeration	"Knock"
Subfinder	Passive sub-domain discovery	Go CLI	Enumeration	"Subfinder"
Raccoon	All-in-one recon with DNS parts	Python tool	Enumeration	"Raccoon"
Turbolist3r	Sub-domain enumeration	Python tool	Enumeration	"Turbolist3r"
dnsenum (ADDED)	DNS enumeration and zone transfer	Perl CLI	Enumeration	"dnsenum"
fierce (ADDED)	DNS scanner for non-contiguous space	Python CLI	Enumeration	"fierce"

4.4 IPsec, VoIP, RPC, Linux/Unix, and AI Tools

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
ike-scan	Finds IKE gateways and reads their SA data	Linux CLI	Scanning and enumeration	"UDP 500, ISAKMP"
svmap	Scans for SIP devices and user agents	SIPVicious CLI	Enumeration	"SIP device, user agent"
svwar (ADDED)	Finds valid SIP extensions	SIPVicious CLI	Enumeration	"SIP extensions"
svcrack (ADDED)	Guesses SIP passwords	SIPVicious CLI	Gaining access	"SIP password crack"
Metasploit SIP options	Sends SIP OPTIONS to a range	Framework module	Enumeration	"SIP OPTIONS scan"
rpcclient (ADDED)	Talks to Windows RPC and lists users	Linux CLI	Enumeration	"enumdomusers"
rpcdump (ADDED)	Dumps RPC endpoints	Impacket script	Enumeration	"RPC endpoint dump"

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
rusers	Lists users logged on to remote hosts	Unix CLI	Enumeration	"remote machines users"
rwho	Lists users on local network hosts	Unix CLI	Enumeration	"local network users"
finger	Shows detail about a user	Unix CLI	Enumeration	"real name, office phone"
ShellGPT (sgpt)	Turns a prompt into a shell command	Python CLI with LLM	All phases	"shell command from prompt"
ChatGPT	Chat AI that builds commands and scripts	Web LLM	All phases	"generative AI prompt"

Close alternatives the exam places next to these tools:

If the tool is	The look-alike is	Difference
nbtstat	netstat	netstat shows TCP connections, not NetBIOS names
snmpwalk	snmp-check	snmpwalk dumps raw OIDs, snmp-check formats a report
ldapsearch	AD Explorer	ldapsearch is CLI, AD Explorer is a GUI viewer
ntpq	ntpdc	ntpq checks performance, ntpdc monitors the daemon
showmount	rpcinfo	showmount lists exports, rpcinfo lists RPC programs
enum4linux	nullinux	enum4linux does many jobs, nullinux focuses on null sessions
dig	nslookup	dig is Linux detail, nslookup works on Windows
Amass	subfinder	Amass maps the surface, subfinder only lists names

5. Command Sheet

You have no lab, so this section teaches you to read each command like a sentence. For every command you get: purpose, syntax, breakdown, flags, demos, a sample output with line-by-line meaning, common mistakes, and what the exam asks. Sample output is realistic but made up; it is not copied from a real system.

5.1 nbtstat

Purpose: Show the NetBIOS name table of a local or remote Windows computer.

Full syntax:

```
nbtstat [-a RemoteName] [-A IPaddress] [-c] [-n] [-r] [-R] [-RR]
        [-s] [-S] [interval]
```

Breakdown:

- `nbtstat` is the program.
- `-a RemoteName` or `-A IPaddress` chooses the target and returns its name table.
- The other switches read local data (cache, names, sessions).

Flag	Meaning	When to use	Example
-a	Name table of a remote host by NAME	You know the host name	nbtstat -a WINDOWS11
-A	Name table of a remote host by IP	You know only the IP	nbtstat -A 10.10.1.11
-c	Show the NetBIOS name cache	See names this PC resolved	nbtstat -c
-n	Show local NetBIOS names	Check own registered names	nbtstat -n
-r	Names resolved by broadcast or WINS	Check name resolution	nbtstat -r
-R	Purge and reload the name cache	Clear stale entries	nbtstat -R
-RR	Release and refresh names with WINS	Re-register names	nbtstat -RR
-s	Sessions table, shows names	See current connections	nbtstat -s
-S	Sessions table, shows IPs	Same, with IP addresses	nbtstat -S
interval	Repeat every N seconds	Watch changes live	nbtstat -n 5

Demo commands (scenario: internal test of 10.10.1.0/24):

```
nbtstat -A 10.10.1.11
nbtstat -a WINDOWS11
nbtstat -c
```

1. First, ask the host at 10.10.1.11 for its name table by IP.
2. Second, ask the same host by name (works only if the name resolves).
3. Third, check which names your own PC has cached after the scan.

Sample output and how to read it:

```
C:\> nbtstat -A 10.10.1.11

Ethernet 2:
Node IpAddress: [10.10.1.16] Scope Id: []

           NetBIOS Remote Machine Name Table

       Name               Type         Status
    ---------------------------------------------
    WINDOWS11      <00>  UNIQUE      Registered
    WORKGROUP      <00>  GROUP       Registered
    WINDOWS11      <20>  UNIQUE      Registered
    WORKGROUP      <1E>  GROUP       Registered
    WORKGROUP      <1D>  UNIQUE      Registered
    ..__MSBROWSE__.<01>  GROUP       Registered

    MAC Address = 00-15-5D-00-0A-01
```

- `Node IpAddress: [10.10.1.16]` is YOUR adapter, not the target.
- `WINDOWS11 <00> UNIQUE` is the host name (workstation service).
- `WORKGROUP <00> GROUP` is the workgroup or domain name.
- `WINDOWS11 <20> UNIQUE` means the file server service is running, so shares may exist.
- `WORKGROUP <1E> GROUP` is the browser election group.
- `WORKGROUP <1D> UNIQUE` means this host is the master browser.
- `..__MSBROWSE__.<01> GROUP` announces the master browser to the subnet.
- `MAC Address` is the hardware address of the target card.

Common mistakes:

- Using `-a` with an IP when the host will not resolve it (use `-A`).
- Running it on a host with NetBIOS off (no reply, "Host not found").
- Reading the node IP as the target IP.

What the exam asks: which command gives the NetBIOS name table of a remote machine (nbtstat), which flag takes an IP (`-A`, with the slide's `-a` form noted), and what code 20 or 1B means.

5.2 net view

Purpose: List the shares of a remote host or the computers of a domain.

Full syntax:

```
net view [\\ComputerName] [/all] [/cache]
net view /domain[:DomainName]
```

Flag	Meaning	When to use	Example
\ComputerName	Target host	List one host's shares	net view \10.10.1.22
/all	Include hidden $ shares	See ADMIN$ and C$	net view \10.10.1.22 /all
/domain	List domains in the network	Find domain names	net view /domain

Flag	Meaning	When to use	Example
/domain:name	List computers in a domain	Map a domain	net view /domain:CEH

Demo commands:

```
net view \\10.10.1.22
net view \\10.10.1.22 /all
net view /domain:CEH
```

1. First, see only the normal shares.
2. Second, add hidden administrative shares.
3. Third, list every computer in the domain `CEH`.

Sample output (matches the slide):

```
C:\> net view \\10.10.1.22 /all
Shared resources at \\10.10.1.22

Share name  Type  Used as  Comment
-------------------------------------------------------
ADMIN$      Disk           Remote Admin
C$          Disk           Default share
IPC$        IPC            Remote IPC
NETLOGON    Disk           Logon server share
SYSVOL      Disk           Logon server share
Users       Disk
The command completed successfully.
```

- `Shared resources at \\10.10.1.22` confirms the target.
- `Type Disk` is a folder or drive. `Type IPC` is the pipe share.
- `NETLOGON` and `SYSVOL` together suggest a domain controller.
- `The command completed successfully` means access worked. An error such as "System error 5" means access denied.

Common mistakes: a single backslash (`\10.10.1.22`), forgetting `/all` and missing hidden shares, and confusing `net view` with `net use`.

What the exam asks: the command that lists shared resources of a remote host, and the syntax of the two forms on the slide.

5.3 snmpwalk

Purpose: Ask an SNMP agent for every value in its MIB, in order.

Full syntax:

```
snmpwalk -v <1|2c|3> -c <community> <host> [OID]
```

Breakdown: `snmpwalk` is the program. `-v` picks the SNMP version. `-c` gives the community string. `host` is the target. An optional `OID` limits the walk to one branch of the tree.

Flag	Meaning	When to use	Example
-v1	Use SNMP version 1	Old devices	snmpwalk -v1 -c public host
-v2c	Use version 2c	Most devices	snmpwalk -v2c -c public host
-c	Community string	Always for v1 and v2c	-c public
-On	Show OIDs as numbers	Easier to compare	snmpwalk -On -v1 -c public host
-t	Timeout in seconds	Slow links	snmpwalk -t 5 -v1 -c public host
-r	Retries	Lossy links	snmpwalk -r 2 -v1 -c public host
-u, -l, -a, -A, -x, -X	SNMPv3 user and security options	v3 targets only	(v3 syntax, verify)

Demo commands (scenario: a switch at 10.10.1.1):

```
snmpwalk -v1 -c public 10.10.1.22
snmpwalk -v2c -c public 10.10.1.1 1.3.6.1.2.1.4.22
snmpwalk -v2c -c private 10.10.1.1 1.3.6.1.2.1.1
```

1. First, the slide command: walk everything with version 1 and the default read string.
2. Second, walk only the ARP table (`ipNetToMediaTable`, OID 1.3.6.1.2.1.4.22).
3. Third, test the default read-write string `private` on the system group.

Sample output and how to read it:

```
$ snmpwalk -v1 -c public 10.10.1.22
iso.3.6.1.2.1.1.1.0 = STRING: "Hardware: Intel64 Family 6 - Software:
 Windows Version 6.3 (Build 20348 Multiprocessor Free)"
iso.3.6.1.2.1.1.3.0 = Timeticks: (35184372) 4 days, 1:44:03.72
iso.3.6.1.2.1.1.5.0 = STRING: "WIN-SRV01.ceh.local"
```

- `iso.3.6.1.2.1.1.1.0` is the OID for `sysDescr`: hardware and OS text. This is OS banner information.
- `Timeticks` under `...1.3.0` is `sysUpTime`: how long the device has been up.
- `...1.5.0` is `sysName`: the device name.
- `STRING:` and `Timeticks:` are the value types.
- A reply means the community string was accepted. `Timeout: No Response` means a wrong string, a blocked port, or no SNMP.

Common mistakes: using TCP scans to find SNMP (it is UDP 161), using v3 options on a v1 device, and forgetting that a wrong string just times out.

What the exam asks: which tool walks the MIB (snmpwalk), the default strings (public, private), and the port (UDP 161).

5.4 Nmap Scripts for Enumeration

Purpose: Use Nmap NSE scripts to enumerate many services with one tool.

Full syntax:

```
nmap [scan type] [-p ports] --script <name> [--script-args k=v] <target>
```

Flag	Meaning	When to use	Example
-sU	UDP scan	SNMP, NTP, IKE, SIP	nmap -sU -p 161 host
-sS	TCP SYN scan	SMTP, SMB, LDAP	nmap -sS -p 25 host
-sV	Detect service versions	Banner and version	nmap -sV -p 445 host
-p	Port list	Pick the service port	-p 389
--script	Run an NSE script	Enumerate data	--script smtp-enum-users
--script-args	Pass options to a script	Give the domain	dns-nsec-enum.domains=x
-Pn	Skip host discovery	Host blocks ping	nmap -Pn -p 445 host
-A	OS, version, script, traceroute	Quick deep scan	nmap -A -p 445 host

Demo commands, one per service:

```
nmap -sU -p 161 --script=snmp-processes 10.10.1.22
nmap -p 25 --script smtp-enum-users 192.168.1.56
nmap -p 389 --script ldap-search 10.10.1.22
nmap -sU -p 500 10.10.1.22
nmap -p 445 --script smb-os-discovery 10.10.1.22
```

1. SNMP processes (the slide command, UDP 161).
2. SMTP users (slide tool, best reading of the command).
3. LDAP entries (best reading of the automated LDAP demo).
4. IPsec gateway check (UDP 500).
5. SMB OS discovery (port 445).

Sample output for SNMP and SMTP, and how to read it:

```
PORT    STATE SERVICE
161/udp open  snmp
| snmp-processes:
|   1:
|     Name: System Idle Process
|   4:
|     Name: System
|   720:
|     Name: svchost.exe
|     Path: C:\windows\system32\
|     Params: -k DcomLaunch -p -s LSM
```

- `161/udp open snmp` proves the SNMP agent answers.
- Each number (1, 4, 720) is a **process ID**. `Name`, `Path`, and `Params` describe it.
- A running service list helps the attacker choose exploits.

```
PORT   STATE SERVICE
25/tcp open  smtp
| smtp-enum-users:
|   root
|   admin
|   administrator
|_  test
```

- `smtp-enum-users` lists names the server accepted. The last line starts with `|_`.
- `open|filtered` on a UDP port (not shown) means no reply, so you cannot tell if it is open.

Common mistakes: scanning SNMP, NTP, IKE, or SIP without `-sU`, scanning too many ports with `-sU` (it is slow), and trusting a script result without a manual check.

What the exam asks: which scan flag fits UDP services, which script name fits a task, and how to read "open" lines.

5.5 ldapsearch

Purpose: Query an LDAP directory from the command line.

Full syntax:

```
ldapsearch -x -H ldap://<host>:<port> -b "<base DN>" [-D "<bind DN>" -W]
           ["<filter>"] [attributes]
```

Flag	Meaning	When to use	Example
-x	Simple authentication (no SASL)	Anonymous or plain bind	ldapsearch -x ...
-H	LDAP server URI	Choose host and port	-H ldap://10.10.1.22:389
-h	Host name (old form, deprecated)	Old docs	-h 10.10.1.22
-b	Base DN, where the search starts	Pick the domain	-b "dc=ceh,dc=local"
-s	Search scope: base, one, sub	Limit depth	-s base
-D	Bind DN, the login name	Authenticated search	-D "cn=admin,dc=ceh"
-W	Prompt for the password	With -D	-W
-LLL	Cleaner output	Easier reading	-LLL

Demo commands (scenario: a directory on 10.10.1.22):

```
ldapsearch -x -H ldap://10.10.1.22 -s base namingContexts
ldapsearch -x -H ldap://10.10.1.22 -b "dc=ceh,dc=local" \
  "(objectClass=person)"
```

1. First, ask the root entry which naming contexts (base DNs) exist.
2. Second, list every person entry under the domain with an anonymous bind.

Sample output and how to read it:

```
dn: cn=John Smith,ou=Sales,dc=ceh,dc=local
cn: John Smith
mail: jsmith@ceh.local
department: Sales

# numResponses: 2
# numEntries: 1
```

- `dn:` is the full path of the entry.
- `cn`, `mail`, and `department` are attributes (the data the attacker wants).
- `numEntries: 1` shows how many entries matched. `result: 32 No such object` would mean the base DN is wrong. `result: 49` or `Invalid credentials` means a bad login.

Common mistakes: a wrong base DN, forgetting `-x` and getting a SASL error, and expecting anonymous binds to work on a hardened server.

What the exam asks: that ldapsearch is the manual LDAP query tool (slide list), and that LDAP uses TCP 389.

5.6 ntptrace

Purpose: Follow a chain of NTP servers from one server back to the primary time source.

Full syntax (slide):

```
ntptrace [-n] [-m maxhosts] [servername/IP_address]
```

Flag	Meaning	When to use	Example
-n	Print IP addresses, not host names	Faster, no DNS	ntptrace -n 10.10.1.5
-m maxhosts	Most servers to follow	Limit the chain	ntptrace -m 5 10.10.1.5
servername/IP	Where to start	Always	ntptrace ntp.local

Demo commands:

```
ntptrace 10.10.1.5
ntptrace -n -m 3 10.10.1.5
```

1. Trace the whole chain from the server at 10.10.1.5.
2. Trace numeric only and stop after three hops.

Sample output and how to read it:

```
$ ntptrace -n 10.10.1.5
10.10.1.5: stratum 3, offset 0.000412, synch distance 0.05021
10.10.0.2: stratum 2, offset 0.000301, synch distance 0.03110
203.0.113.9: stratum 1, offset -0.000118, synch distance 0.00842
```

- Each line is one server. The first line is the one you asked.
- `stratum` falls by 1 at each step. Stratum 1 is the primary source.
- `offset` is the time difference in seconds. `synch distance` is how far the server is from its source.

- The attacker learns the IPs of internal and upstream time servers.

Common mistakes: expecting a client list (ntptrace shows servers only), and forgetting that firewalls may block UDP 123 on the upper hops.

What the exam asks: "traces a chain of NTP servers back to the primary source" -> ntptrace.

5.7 ntpdc

Purpose: Query and monitor the operation of the NTP daemon (ntpd). The tool is old.

Full syntax (slide):

```
ntpdc [-ilnps] [-c command] [host] [...]
```

Flag	Meaning	When to use	Example
-i	Interactive mode	Run many commands	ntpdc -i 10.10.1.5
-l	List peers (same as listpeers)	Show peers	ntpdc -l 10.10.1.5
-n	Numeric addresses only	Skip DNS	ntpdc -n -c peers host
-p	Print peers (same as peers)	Show peers	ntpdc -p 10.10.1.5
-s	Peer summary (dmpeers form, verify)	Short view	ntpdc -s 10.10.1.5
-c command	Run one command	Script it	ntpdc -c sysinfo host

Demo commands:

```
ntpdc -c sysinfo 10.10.1.5
ntpdc -c peers 10.10.1.5
ntpdc -c monlist 10.10.1.5
```

1. System information of the daemon.
2. The peers the server talks to.
3. The recent client list (`monlist`, ADDED CONTEXT; many servers now refuse it).

Sample output (ADDED CONTEXT) and how to read it:

```
$ ntpdc -c monlist 10.10.1.5
remote address    port local address   count m ver
10.10.1.20       51234 10.10.1.5           9 3   4
10.10.1.31       43121 10.10.1.5           4 3   4
```

- `remote address` is a client that asked this server for the time.
- `count` is how many packets it sent. `m` is the NTP mode and `ver` is the NTP version.
- This list is how an attacker learns client IPs.

Common mistakes: expecting `monlist` to work on a patched server, and using ntpdc on a system that ships only ntpq.

What the exam asks: "monitors operation of the NTP daemon, ntpd" -> ntpdc. The slide callout says ntpdc queries can obtain additional NTP server information.

5.8 ntpq

Purpose: Query the NTP daemon and check how well it performs (the standard tool today).

Full syntax (slide):

```
ntpq [-inp] [-c command] [host] [...]
```

Flag	Meaning	When to use	Example
-i	Interactive mode	Many queries	ntpq -i 10.10.1.5
-n	Numeric addresses	Skip DNS	ntpq -n -p 10.10.1.5
-p	Print the peer list	Check sync sources	ntpq -p 10.10.1.5
-c command	Run one command	Script it	ntpq -c readvar host

Demo commands:

```
ntpq -p 10.10.1.5
ntpq -c readvar 10.10.1.5
ntpq -c associations 10.10.1.5
```

1. List peers and their quality.
2. Read system variables (version, OS, stratum).
3. List peer associations and their status.

Sample output and how to read it:

```
$ ntpq -p 10.10.1.5
     remote       refid      st t when poll reach  delay  offset jitter
==============================================================================
*10.10.0.2    203.0.113.9     2 u   34   64  377  0.512   0.301  0.044
+10.10.1.6    10.10.0.2       3 u   12   64  377  0.610  -0.120  0.080
```

- `*` marks the peer this server uses as its time source. `+` marks a good backup.
- `refid` is the source that peer uses. `st` is the stratum.
- `t u` means unicast. `when` is seconds since the last poll. `poll` is the poll interval in seconds.
- `reach 377` (octal) means the last 8 polls all worked.
- `delay`, `offset`, and `jitter` are in milliseconds. Low numbers mean a healthy link.

Common mistakes: reading `reach` as a normal number (it is octal), and thinking `-p` means "port".

What the exam asks: "monitors ntpd and determines performance" -> ntpq. `-p` prints peers.

5.9 showmount

Purpose: List the folders an NFS server exports, and sometimes the clients that use them.

Full syntax:

```
showmount [-e | -a | -d] <host>
```

Flag	Meaning	When to use	Example
-e	Show the export list	Find shared folders	showmount -e 10.10.1.9
-a	Show clients and the folders they mounted	Find client IPs	showmount -a 10.10.1.9
-d	Show only mounted directories	Find folders in use	showmount -d 10.10.1.9

Demo commands:

```
showmount -e 10.10.1.9
showmount -a 10.10.1.9
```

1. The slide command: list exports.
2. ADDED CONTEXT: list which clients have mounted them.

Sample output (slide) and how to read it:

```
$ showmount -e 10.10.1.9
Export list for 10.10.1.9:
/home *
```

- `Export list for 10.10.1.9:` names the server.
- `/home` is the exported (shared) folder.
- `*` means every client may mount it. A better setting is a list of named hosts.

Common mistakes: forgetting `-e`, and expecting output when the NFS mount daemon is firewalled.

What the exam asks: "list exported directories of an NFS server" -> `showmount -e`.

5.10 rpcinfo

Purpose: Ask the portmapper which RPC programs a host runs and on which ports.

Full syntax:

```
rpcinfo -p <host>
```

Flag	Meaning	When to use	Example
-p	Probe the portmapper and print a program list	See RPC and NFS services	rpcinfo -p 10.10.1.13
-s	Short, compact list (ADDED)	Quick view	rpcinfo -s 10.10.1.13
-t	Test a TCP program call (ADDED)	Check one service	rpcinfo -t host nfs 3

Demo commands:

```
rpcinfo -p 10.10.1.13
rpcinfo -p 10.10.1.13 | grep nfs
```

1. The slide command: print every registered RPC program.
2. Filter the list to the NFS lines.

Sample output (slide) and how to read it:

```
$ rpcinfo -p 10.10.1.13
   program vers proto   port  service
    100000    4   tcp    111  portmapper
    100000    3   tcp    111  portmapper
    100024    1   udp  50883  status
    100005    1   tcp  38127  mountd
    100003    3   tcp   2049  nfs
    100003    4   tcp   2049  nfs
    100021    1   udp  55478  nlockmgr
```

- `program 100000 portmapper port 111` is the RPC directory itself.
- `100005 mountd` handles mount requests (the port is random).
- `100003 nfs` on `2049` proves an NFS server is running. The slide callout says exactly this.
- `vers` is the protocol version (NFS 3 and 4 here). `proto` is tcp or udp.

Common mistakes: thinking `portmapper` is NFS (it is the directory), and forgetting that the `mountd` port changes at each reboot.

What the exam asks: "result displaying an open NFS port and an NFS service" -> `rpcinfo -p`. Program number 100003 = NFS.

5.11 telnet for SMTP (VRFY, EXPN, RCPT TO)

Purpose: Talk to an SMTP server by hand and test whether a user exists.

Full syntax:

```
telnet <host> 25
```

After the connection opens, type SMTP commands, one per line:

SMTP command	Meaning	Good reply	Bad reply
HELO name	Greet the server	250 Hello	501 needs domain
VRFY user	Verify one user	250 with address	550 User unknown
EXPN list	Expand a list or alias	250 with members	550 User unknown
MAIL FROM:user	Name the sender	250 Sender ok	5xx
RCPT TO:user	Name the recipient	250 Recipient ok	550 User unknown
QUIT	End the session	221 Bye	none

Demo commands (scenario: mail gateway at 192.168.1.1):

```
telnet 192.168.1.1 25
HELO test
VRFY admin
EXPN staff
MAIL FROM:test
RCPT TO:admin
QUIT
```

1. Connect to port 25.

2. Say hello with any name.
3. Check the user `admin` and the alias `staff`.
4. Use the delivery path (`MAIL FROM`, then `RCPT TO`) as a second test.
5. Quit cleanly.

Sample output and how to read it: see the three transcripts in 3.10. Key lines:

- `220 ... ESMTP Sendmail 8.9.3` is the banner. It names the product and version, which is useful for the attacker.
- `250 Super-User <Jonathan@NMailserver>` means the user is real.
- `550 Smith... User unknown` means no such user.

Common mistakes: skipping `HELO`, using `RCPT TO` before `MAIL FROM`, and treating `252` or `502` as "no such user" (they mean the server will not tell).

What the exam asks: the three commands, their meaning, and the port (25).

5.12 smtp-user-enum

Purpose: Test many usernames against an SMTP server with VRFY, EXPN, or RCPT TO.

Full syntax:

```
smtp-user-enum [options] (-u user | -U file) (-t host | -T file)
```

Flag	Meaning	When to use	Example
-M mode	Method: VRFY, EXPN, or RCPT	Pick the test	-M RCPT
-u user	One username	Quick check	-u admin
-U file	File of usernames	Real test	-U users.txt
-t host	One target host	Single server	-t 192.168.1.56
-T file	File of target hosts	Many servers	-T hosts.txt
-p port	TCP port (default 25)	Non-standard port	-p 587
-D domain	Domain to add to names	With RCPT mode	-D example.com
-v	Verbose output	See each try	-v

Demo commands:

```
smtp-user-enum -M VRFY -U users.txt -t 192.168.1.56
smtp-user-enum -M RCPT -U users.txt -t 192.168.1.56 -D example.com
```

1. Use VRFY first (fast and simple).
2. If VRFY is blocked, switch to RCPT and add the mail domain.

Sample output and how to read it:

```
$ smtp-user-enum -M VRFY -U users.txt -t 192.168.1.56
Starting smtp-user-enum v1.2 ( pentestmonkey.net/tools/smtp-user-enum )

Mode ..................... VRFY
Worker Processes ......... 5
Usernames file ........... users.txt
Target count ............. 1
Username count ........... 4
Target TCP port .......... 25
Query timeout ............ 5 secs

######## Scan started at Thu Oct 29 10:00:00 2026 #########
192.168.1.56: administrator exists
192.168.1.56: root exists
######## Scan completed at Thu Oct 29 10:00:01 2026 #########
2 results.

4 queries in 1 seconds (4.0 queries / sec)
```

- The header block is the scan information: method, workers, wordlist, target count, port, timeout.
- Each `host: name exists` line is a valid user. Names that do not appear do not exist (or the server hides them).
- `2 results` of `4 queries` means 2 of the 4 names are real.

Common mistakes: using VRFY on a server that answers `252` for everything (false positives), forgetting `-D` in RCPT mode when the server wants full addresses, and using too many workers (the server may block you).

What the exam asks: that smtp-user-enum (pentestmonkey) is the SMTP user tester, and that `-M` picks VRFY, EXPN, or RCPT.

5.13 Metasploit Modules: smtp_enum and SIP options

Purpose: Use Metasploit auxiliary scanner modules to enumerate SMTP users and SIP devices. An **auxiliary module** scans or tests but does not exploit.

Full syntax pattern:

```
msf6 > use <module path>
msf6 module > set <OPTION> <value>
msf6 module > run
```

Command	Meaning	When to use	Example
use	Load a module	Start	use auxiliary/scanner/smtp/smtp_enum
show options	List settings	See what to set	show options
set RHOSTS	Target host or range	Always	set RHOSTS 192.168.1.56
set RPORT	Target port	Non-default port	set RPORT 25
set USER_FILE	Wordlist (smtp_enum)	Custom names	set USER_FILE users.txt
run	Start the module	After setting options	run

Demo commands:

```
use auxiliary/scanner/smtp/smtp_enum
set RHOSTS 192.168.1.56
run
use auxiliary/scanner/sip/options
set RHOSTS 192.168.0.0/24
run
```

1. SMTP: load `smtp_enum`, set the target, run.
2. VoIP: load the SIP OPTIONS scanner (best reading, 3.17), set a /24 range, run.

Sample output and how to read it:

```
[*] 192.168.1.56:25 - Banner: 220 metasploitable.localdomain ESMTP Postfix
[+] 192.168.1.56:25 - Users found: backup, bin, daemon, games, root
```

- `[*]` is information. `[+]` is a positive finding.
- `Banner` shows the SMTP product (Postfix) and the domain (`localdomain`).
- `Users found` lists accounts the server confirmed.

```
[*] Sending SIP OPTIONS to 192.168.0.0-192.168.0.255 (256 hosts)
[+] 192.168.0.94:5060 udp SIP/2.0 200 OK
    'User-Agent'=>'Grandstream HT503'
[*] Scanned 256 of 256 hosts (100% complete)
```

- `200 OK` means a SIP device answered.
- `User-Agent` is the phone or adapter model. `Allow` (not shown) lists the SIP methods it supports.
- `Scanned 256 of 256` shows the scan finished.

Common mistakes: forgetting `set RHOSTS`, using `exploit` instead of `run` on a scanner (both work, but `run` is the usual word), and scanning without a signed scope.

What the exam asks: that Metasploit has an SMTP enumeration module and a SIP scanner, and that `RHOSTS` is the target option.

5.14 dig

Purpose: Query DNS in detail. In this module it asks for name servers and tries a zone transfer.

Full syntax:

```
dig [@server] <name> [type] [options]
```

Part	Meaning	When to use	Example
@server	Ask this DNS server	Query one name server	@ns1.bluehost.com
name	Domain to look up	Always	certifiedhacker.com
ns	Ask for NS records	Find name servers	dig ns domain
axfr	Ask for a full zone transfer	Test AXFR	dig @ns domain axfr

Part	Meaning	When to use	Example
+short	Short answer only	Clean output	dig +short ns domain
-x	Reverse lookup	IP to name	dig -x 10.10.1.5

Demo commands (slide):

```
dig ns www.certifiedhacker.com
dig @ns1.bluehost.com www.certifiedhacker.com axfr
```

1. Find the name servers.
2. Ask one of them for the whole zone.

Sample output and how to read it:

```
$ dig ns certifiedhacker.com
;; ANSWER SECTION:
certifiedhacker.com.  14399  IN  NS  ns1.bluehost.com.
certifiedhacker.com.  14399  IN  NS  ns2.bluehost.com.

$ dig @ns1.bluehost.com certifiedhacker.com axfr
; Transfer failed.
```

- `ANSWER SECTION` holds the records. `14399` is the TTL (seconds the record may be cached).
- `IN` means the Internet class. `NS` is the record type. The last field is the value.
- `; Transfer failed.` means the server refused AXFR (good for the defender).
- A successful AXFR would list every record of the zone (SOA, NS, A, MX, CNAME) and end with the SOA again.

Common mistakes: asking a recursive resolver such as 8.8.8.8 for AXFR (it will not allow it), forgetting `@server`, and reading "Transfer failed" as a tool error.

What the exam asks: the syntax `dig @server domain axfr` and what a failed result means.

5.15 nslookup

Purpose: Query DNS on Windows (and Linux) and try a zone transfer in interactive mode.

Full syntax:

```
nslookup                      (starts interactive mode)
> set querytype=ns            (or: set type=ns)
> <domain>
> server <name server>
> ls -d <domain>
```

Command	Meaning	When to use	Example
set querytype=ns	Next lookups return NS records	Find name servers	set querytype=ns

Command	Meaning	When to use	Example
server name	Switch to another DNS server	Ask the target's server	server ns1.bluehost.com
set type=any	Ask for all record types	Wider answers	set type=any
ls -d domain	List the whole zone (AXFR)	Test zone transfer	ls -d certifiedhacker.com
exit	Leave interactive mode	When done	exit

Demo commands (slide scenario):

```
C:\> nslookup
> set querytype=ns
> certifiedhacker.com
> server ns1.bluehost.com
> ls -d certifiedhacker.com
```

Sample output and how to read it:

```
Non-authoritative answer:
certifiedhacker.com  nameserver = ns1.bluehost.com
certifiedhacker.com  nameserver = ns2.bluehost.com

ns1.bluehost.com
        primary name server = ns1.bluehost.com
        serial  = 2024051000
        refresh = 86400 (1 day)
        retry   = 7200 (2 hours)
        expire  = 1209600 (14 days)
        default TTL = 180 (3 mins)
*** Can't list domain certifiedhacker.com: Server failed
```

- `Non-authoritative answer` means a cache answered, not the zone owner.
- `nameserver =` lines are the NS records.
- The SOA block shows how the secondary servers refresh (serial, refresh, retry, expire, default TTL).
- `Can't list domain ... Server failed` means the zone transfer was refused. The slide shows the same refusal.

Common mistakes: using `ls -d` before switching to the target's own name server, and a typo in the zone name.

What the exam asks: nslookup steps for a zone transfer (`set querytype=ns`, `server`, `ls -d`) and what a refusal looks like.

5.16 dnsrecon

Purpose: Run many DNS checks: zone transfer, brute force, and DNSSEC zone walking.

Full syntax:

```
dnsrecon -d <domain> [-t <type>] [-n <name server>] [-D <wordlist>] [-z]
```

Flag	Meaning	When to use	Example
-d	Target domain	Always	dnsrecon -d example.com

Flag	Meaning	When to use	Example
-t axfr	Try a zone transfer	Test AXFR	dnsrecon -d example.com -t axfr
-t brt	Brute force sub-domains	Guess names	-t brt -D names.txt
-t std	Standard record lookups	First pass	-t std
-n	Name server to ask	Use the target's server	-n 10.10.1.2
-D	Wordlist file	With brute force	-D names.txt
-z	DNSSEC zone walk	Signed zones	dnsrecon -d example.com -z

Demo commands:

```
dnsrecon -d www.certifiedhacker.com -z
dnsrecon -d example.com -t axfr
```

1. The slide command: standard enumeration plus an NSEC zone walk.
2. A zone transfer test (ADDED CONTEXT).

Sample output and how to read it:

```
[*] DNSSEC is not configured for www.certifiedhacker.com
[*]      SOA ns1.bluehost.com 162.159.24.80
[*]      NS ns1.bluehost.com 162.159.24.80
[*]      MX mail.certifiedhacker.com 162.241.216.11
[*]      A www.certifiedhacker.com 162.241.216.11
[*]      TXT www.certifiedhacker.com v=spf1 a mx ptr include:bluehost.com
[*] Enumerating SRV Records
[-] 0 Records Found
```

- `DNSSEC is not configured` means no NSEC walk is possible, so the tool does standard lookups.
- `SOA`, `NS`, `MX`, `A`, `TXT` lines are the records found. The IP is on the right.
- The TXT line is an SPF policy (it lists servers allowed to send mail).
- `0 Records Found` for SRV means no service records exist.

Common mistakes: expecting a walk on an unsigned zone, using `-t` with a wrong type name, and running brute force without a wordlist.

What the exam asks: that `-z` is the DNSSEC zone walk and that DNSRecon is on the zone transfer tool list.

5.17 ldns-walk

Purpose: Walk the NSEC chain of a DNSSEC-signed zone and list its names.

Full syntax:

```
ldns-walk @<server> <domain>
```

Breakdown: `@server` is the DNS server to ask (the slide uses `8.8.8.8`). `domain` is the signed zone. Extra options exist (verify with `ldns-walk -h`).

Demo command (slide):

```
ldns-walk @8.8.8.8 nlnetlabs.nl
```

Sample output and how to read it:

```
nlnetlabs.nl. A NS SOA MX TXT AAAA RRSIG NSEC DNSKEY
_dmarc.nlnetlabs.nl. TXT RRSIG NSEC
bela.nlnetlabs.nl. A AAAA RRSIG NSEC
mail.nlnetlabs.nl. A AAAA RRSIG NSEC
```

- Each line is one name in the zone, followed by the record types that exist at that name.
- Names appear in sorted order because each NSEC record points to the next name.
- `RRSIG` is the signature. `NSEC` is the next-name pointer. These two appear on every line of a signed zone.

Common mistakes: running it on an unsigned zone (no NSEC records), and on an NSEC3 zone (names are hashed, so the walk shows hashes).

What the exam asks: LDNS and DNSRecon are the zone walking tools on the slide.

5.18 amass

Purpose: Map a domain's sub-domains, IPs, and networks (the attack surface), and compare scans over time.

Full syntax:

```
amass enum [-passive | -active] -d <domain> [-brute -w <wordlist>] [-src]
amass track -config <file> -dir <folder> -d <domain> -last <N>
```

Flag	Meaning	When to use	Example
-passive	Public sources only	Stay quiet	amass enum -passive -d example.com
-active	Also probe the target	Deeper results	amass enum -active -d example.com
-brute	Guess names	Find hidden hosts	-brute -w all.txt
-w	Wordlist path	With -brute	-w /usr/share/wordlists/amass/all.txt
-src	Show data source	Judge sources	-src
-dir	Database folder	Save history	-dir amass4owasp
-last 2	Compare last two runs (track)	Spot changes	track ... -last 2

Demo commands (slide):

```
amass enum -passive -d certifiedhacker.com -src
amass enum -active -d certifiedhacker.com -brute -w \
  /usr/share/wordlists/amass/all.txt
amass track -config /root/amass/config.ini -dir amass4owasp \
  -d certifiedhacker.com -last 2
```

Sample output and how to read it:

```
mail.certifiedhacker.com (FQDN) --> a_record --> 162.241.216.11 (IPAddress)
162.241.216.0/24 (Netblock) --> contains --> 162.241.216.11 (IPAddress)
26337 (ASN) --> announces --> 162.241.216.0/24 (Netblock)
```

- Line 1: the host `mail` points to 162.241.216.11 by an A record.
- Line 2: that IP sits inside the netblock 162.241.216.0/24.
- Line 3: ASN 26337 announces (owns the route for) that netblock.
- With `-src` each name also shows the source that found it.

Common mistakes: thinking `-passive` touches the target (it does not), forgetting the wordlist after `-brute`, and using old flags on Amass v4 (verify).

What the exam asks: the three slide commands and what `-passive`, `-active`, `-brute -w`, and `track -last 2` do.

5.19 ike-scan

Purpose: Find IKE (IPsec VPN) gateways and read the settings they accept.

Full syntax:

```
ike-scan [options] <target>
```

Flag	Meaning	When to use	Example
-M	Multi-line output	Easier reading	ike-scan -M 10.10.1.22
-A	Aggressive mode	Test PSK exposure	ike-scan -A 10.10.1.22
--id=name	Group name for aggressive mode	With -A	ike-scan -A --id=vpn host
-P file	Save PSK data for cracking	After a -A hit	ike-scan -A -P psk.txt host
-f file	Read targets from a file	Many hosts	ike-scan -f hosts.txt
--nat-t	Use UDP 4500	NAT-T gateways	ike-scan --nat-t host
-v	Verbose	Debug	ike-scan -v host

Demo commands:

```
nmap -sU -p 500 10.10.1.22
ike-scan -M 10.10.1.22
```

1. First, check that UDP 500 is open (the slide Nmap step).
2. Second, send IKE proposals and read the reply.

Sample output and how to read it:

```
Starting ike-scan 1.9.5 with 1 hosts
10.10.1.22  Notify message 14 (NO-PROPOSAL-CHOSEN)
Ending ike-scan 1.9.5: 1 hosts scanned. 0 returned handshake;
1 returned notify
```

- `NO-PROPOSAL-CHOSEN` means the gateway is alive but did not like the test proposal.

```
10.10.1.22  Main Mode Handshake returned
        SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK
            LifeType=Seconds LifeDuration=28800)
```

- `Enc` is the encryption algorithm. `Hash` is the hash algorithm.
- `Group=2:modp1024` is the Diffie-Hellman group (the key exchange method).
- `Auth=PSK` is the authentication type (pre-shared key).
- `LifeDuration=28800` is the SA lifetime in seconds (8 hours).
- These are the items the slide says ike-scan enumerates.

Common mistakes: scanning TCP 500, treating a notify reply as "no VPN", and using aggressive mode without permission (it can leak a crackable hash).

What the exam asks: the tool name (ike-scan), the port (UDP 500), and the four data items.

5.20 sgpt (ShellGPT)

Purpose: Turn a plain-English prompt into a shell command, with a chance to run it.

Full syntax:

```
sgpt [options] "<prompt>"
```

Flag	Meaning	When to use	Example
--shell (or -s)	Return a shell command	Build a command	sgpt --shell "..."
--describe-shell (or -d)	Explain a shell command	Learn flags	sgpt -d "nmap -sU -p 500 host"
--code (or -c)	Return code only	Scripts	sgpt --code "python port scan"
--chat name	Keep a conversation	Follow-up prompts	sgpt --chat recon "..."

Demo commands (slide prompts):

```
sgpt --shell "Perform IPsec enumeration on target IP 10.10.1.22 with nmap"
sgpt --shell \
  "Scan the target IP 10.10.1.22 for the port using SMB with nmap"
```

Sample output and how to read it:

```
nmap -sU -p 500 10.10.1.22
[E]xecute, [D]escribe, [A]bort: E
PORT    STATE SERVICE
500/udp open  isakmp
```

- The first line is the command the model wrote. Check each flag.
- `[E]xecute, [D]escribe, [A]bort` is the safety prompt. Press D to see an explanation before you run it.
- The rest is normal Nmap output. `isakmp` on UDP 500 shows a VPN gateway.

Common mistakes: pressing E without reading, trusting wrong flags, and running it outside your scope.

What the exam asks: that ShellGPT builds shell commands from prompts, and the two slide prompts (IPsec and SMB).

5.21 svmap

Purpose: Scan IP addresses for SIP devices and report their user agent. It belongs to the SIPVicious suite.

Full syntax:

```
svmap [options] <host | range>
```

Flag	Meaning	When to use	Example
host or range	One IP or a CIDR range	Always	svmap 192.168.0.0/24
-p ports	Ports to scan (default 5060)	Non-standard ports	svmap -p 5060-5061 host
-t seconds	Reply timeout (verify)	Slow links	svmap -t 5 host
-v	Verbose	See each probe	svmap -v host

Demo commands:

```
svmap 151.50.106.225
svmap 192.168.0.0/24
```

1. The slide command: scan one address.
2. Scan a whole phone VLAN.

Sample output (slide) and how to read it:

```
+----------------------+------------------+
| SIP Device           | User Agent       |
+======================+==================+
| 151.50.106.225:5060  | DLink VoIP Stack |
+----------------------+------------------+
```

- `SIP Device` is the address and port that answered.
- `User Agent` is the device model or software. This tells the attacker which firmware bugs and default passwords to try.

Common mistakes: scanning only TCP (svmap uses UDP by default), and forgetting that some devices listen on other ports.

What the exam asks: that svmap finds SIP devices (VoIP enumeration).

5.22 rusers

Purpose: List users logged in on remote hosts of the local network.

Full syntax (slide):

```
/usr/bin/rusers [-a] [-l] [-u| -h| -i] [Host ...]
```

Flag	Meaning	When to use	Example
-a	Report a machine even if nobody is logged in	Find all hosts	rusers -a
-l	Long format (login time, idle time)	More detail	rusers -l host
-u	Sort by number of users	Busiest hosts	rusers -u
-h	Sort by host name	Tidy list	rusers -h
-i	Sort by idle time	Find inactive users	rusers -i

Demo commands:

```
rusers -a
rusers -l 10.10.1.5
```

Sample output (ADDED CONTEXT) and how to read it:

```
$ rusers -l 10.10.1.5
admin1   10.10.1.5:tty1   Oct 29 08:01   6:02
```

- `admin1` is the login name, `10.10.1.5:tty1` the host and terminal, then the login time and the idle time.
- Sorting flags (`-u`, `-h`, `-i`) change the order, not the content.

Common mistakes: expecting output from a host where the rusers service is off.

What the exam asks: which of the three commands lists logged-in users on remote machines.

5.23 rwho

Purpose: Show users logged in on hosts of the local network that run the rwho daemon.

Full syntax (slide):

```
rwho [ -a]
```

Flag	Meaning	When to use	Example
-a	Include users idle for over an hour	Full list	rwho -a

Demo command:

```
rwho -a
```

Sample output (ADDED CONTEXT):

```
$ rwho -a
admin1   buildsrv:tty1   Oct 29 08:01
guest    labpc01:pts/0   Oct 29 07:12 :45
```

- Fields: user, host and terminal, login time, and (if idle) idle time like `:45`.
- Only hosts that run `rwhod` on the same network segment appear.

Common mistakes: thinking rwho can reach other networks (it uses local broadcasts).

What the exam asks: "users logged on to hosts on the local network" -> rwho.

5.24 finger

Purpose: Show details about system users (login, real name, shell, login time, plan file).

Full syntax (slide):

```
finger [-l] [-m] [-p] [-s] [user ...] [user@host ...]
```

Flag	Meaning	When to use	Example
-l	Long, multi-line format	Full details	finger -l ubuntu
-s	Short, one-line format	Quick list	finger -s
-m	Match login names only, not real names	Exact match	finger -m ubu
-p	Do not show .plan and .project files	Less output	finger -p ubuntu
user@host	Ask a remote host	Remote check	finger ubuntu@10.10.1.5

Demo commands (slide):

```
finger
finger ubuntu
finger ubuntu@10.10.1.5
```

Sample output (slide) and how to read it:

```
$ finger ubuntu
Login: ubuntu                     Name: Ubuntu
Directory: /home/ubuntu           Shell: /bin/bash
On since Tue Mar 12 03:23 (EDT) on :1 from :1 (messages off)
No mail.
No Plan.
```

- `Login` and `Name` are the account name and real name.
- `Directory` and `Shell` show the home path and login shell.
- `On since ...` shows when the user logged in and from where. `(messages off)` means the user blocks terminal messages.
- `No Plan` means the `.plan` file is empty. Users sometimes put phone numbers there.

Common mistakes: finger only works if the service runs (TCP 79) for remote queries.

What the exam asks: that finger gives real name, office, and phone details.

5.25 SMB Tools: enum4linux, SMBMap, nullinux

Purpose: Pull users, shares, groups, and policy from SMB hosts.

Command	Meaning	When to use	Example
enum4linux -a	Run all basic checks	First pass	enum4linux -a 10.10.1.22

Command	Meaning	When to use	Example
enum4linux -U	List users	Need accounts	enum4linux -U 10.10.1.22
enum4linux -S	List shares	Need shares	enum4linux -S 10.10.1.22
enum4linux -P	Password policy	Plan guessing	enum4linux -P 10.10.1.22
enum4linux -o	OS information	Banner grab	enum4linux -o 10.10.1.22
smbmap -H	Shares and permissions	Check access	smbmap -H 10.10.1.22
smbmap -u -p	Log in with a user	After finding creds	smbmap -H host -u user -p pass
nullinux host	Null-session user listing (verify options)	Quick user list	nullinux 10.10.1.22

Demo commands:

```
enum4linux -a 10.10.1.22
smbmap -H 10.10.1.22
nullinux 10.10.1.22
nmap -p 445 --script smb-os-discovery 10.10.1.22
```

Sample output and how to read it:

```
[+] Server 10.10.1.22 allows sessions using username '', password ''
index: 0x1 RID: 0x1f4 acb: 0x00000210 Account: Administrator
Sharename   Type   Comment
---------   ----   -------
IPC$        IPC    Remote IPC
Users       Disk
```

- `allows sessions using username '', password ''` means a null session works. This is the main finding.
- `RID: 0x1f4` is hex for 500, the built-in Administrator account.
- The share table shows `IPC$` and `Users`. Disk shares are file locations.

Common mistakes: running them on a hardened host and thinking "no output" means "no users", and forgetting that SMB signing or SMBv1 settings change results.

What the exam asks: the tool names from the slide (Nmap, SMBMap, enum4linux, nullinux) and port 445.

6. Ports, Protocols, Standards and Acronyms

6.1 Service Ports Used in Enumeration

Protocol	Default port or layer	Purpose	Known weakness	Related attack or tool
DNS	TCP/UDP 53	Name to IP lookups	Open zone transfer	dig axfr, nslookup, DNSRecon
SMTP	TCP 25	Mail between servers	VRFY, EXPN, open relay	telnet, smtp-user-enum
NTP	UDP 123	Clock sync	Peer and client leaks	ntpq, ntpdc, ntptrace
SNMP	UDP 161	Device management	Default community strings	snmpwalk, snmp-check
SNMP trap	UDP 162	Device alerts	Clear text in v1, v2c	NMS trap listeners
LDAP	TCP/UDP 389	Directory queries	Clear text, anonymous bind	ldapsearch, AD Explorer
LDAPS	TCP 636	LDAP over TLS	Weak certificates	Same tools with TLS
Global Catalog	TCP 3268	AD forest search	Same as LDAP	ldapsearch
NetBIOS name	UDP 137	Name lookup	Leaks host data	nbtstat, NetBIOS Enumerator
NetBIOS datagram	UDP 138	Connectionless messages	Broadcast leaks	nbtscan
NetBIOS session	TCP 139	SMB over NetBIOS	Null sessions	enum4linux
SMB	TCP 445	File and printer sharing	Null session, old SMBv1	Nmap, SMBMap, nullinux
MS RPC mapper	TCP/UDP 135	Finds RPC services	Service exposure	rpcdump, NetScanTools
Portmapper	TCP/UDP 111	Unix RPC directory	Lists NFS and others	rpcinfo -p
NFS	TCP/UDP 2049	Unix file sharing	Wide exports, no_root_squash	showmount -e
ISAKMP/IKE	UDP 500	IPsec key exchange	Aggressive mode PSK hash	ike-scan
IPsec NAT-T	UDP 4500	IPsec through NAT	Same as IKE	ike-scan --nat-t
SIP	UDP/TCP 5060	VoIP call setup	Clear text, defaults	svmap, Metasploit SIP
SIP TLS	TCP 5061	SIP over TLS	Weak certificates	svmap
SIP slide ports	2000, 2001	Listed on the slide with SIP	Verify use	svmap
finger	TCP 79	User information	Leaks real names	finger user@host
rwho	UDP 513 (verify)	Who is on the LAN	Broadcast leaks	rwho

> **EXAM TIP:** The slide gives these directly: LDAP TCP 389, SMB 445 (and 139 in countermeasures), NFS 2049, ISAKMP UDP 500, SIP 2000 / 2001 / 5060 / 5061. Learn these first.

6.2 NetBIOS Suffix Codes

Code	Type	Meaning	On slide?	Note
00	UNIQUE	Hostname (workstation)	Yes	Same code for the domain as GROUP
00	GROUP	Domain or workgroup name	Yes	
01	GROUP	**MSBROWSE**	Output only	Master browser announcement
03	UNIQUE	Messenger service	Yes	Computer and logged-in user
20	UNIQUE	Server (file sharing) service	Yes	Shares may exist
1B	UNIQUE	Domain master browser (PDC)	Yes	
1C	GROUP	Domain controllers	Added	
1D	GROUP or UNIQUE	Master browser for subnet	Yes	Slide: GROUP, output: UNIQUE
1E	GROUP	Browser election	Output only	

6.3 SMTP Reply Codes

Code	Meaning	Enumeration use
220	Service ready (banner)	Read product and version
250	Command accepted	User exists
251	User not local, will forward	Valid but remote
252	Cannot verify, will accept	Server hides answers
421	Service not available	Server busy or blocking
501	Syntax error in arguments	Fix the command
502	Command not implemented	VRFY or EXPN disabled
550	Mailbox unavailable	User does not exist

6.4 SNMP Quick Facts

Item	Fact	Why it matters
Agent port	UDP 161	The scan target
Trap port	UDP 162	Alerts sent to the NMS
Default read-only string	public	Lets attackers read data
Default read-write string	private	Lets attackers change data

Item	Fact	Why it matters
SNMPv1 and v2c	Clear text community string	Sniffing reveals the string
SNMPv3	Authentication and encryption	The recommended fix
MIB	Tree of values	Walked by snmpwalk
OID 1.3.6.1.2.1.1.1.0	sysDescr	OS and hardware text
OID 1.3.6.1.2.1.1.3.0	sysUpTime	Uptime
OID 1.3.6.1.2.1.1.5.0	sysName	Device name
OID 1.3.6.1.2.1.4.22	ARP table	Neighbours

6.5 DNS and DNSSEC Records

Record	Meaning	Enumeration use
A	Host to IPv4	Host list
AAAA	Host to IPv6	Host list
NS	Name server	Servers to ask for AXFR
MX	Mail server	Mail hosts
CNAME	Alias	Hidden hosts
SOA	Zone authority and timers	Serial, refresh, retry, expire
TXT	Text, SPF	Mail policy and tokens
SRV	Service location	Service hosts
PTR	IP to host	Reverse lookup
DNSKEY	Zone public key	DNSSEC
RRSIG	Record signature	Appears with NSEC
NSEC	Next existing name	Zone walking
NSEC3	Hashed next name	Harder walking
DS	Delegation signer	Parent to child trust

6.6 SIP Methods

Method	Meaning
INVITE	Start a call
ACK	Confirm a final response
BYE	End a call
CANCEL	Stop a pending call
OPTIONS	Ask what the device supports (used by scanners)
REGISTER	Tell the server where a user is
SUBSCRIBE	Ask for event updates
NOTIFY	Send an event update
INFO	Send extra mid-call data
REFER	Transfer a call

Method	Meaning
UPDATE	Change call parameters
MESSAGE	Send an instant message

The `Allow` line in the Metasploit screenshot lists most of these methods.

6.7 Rare Protocols in Plain Words

NTP (Network Time Protocol). *What:* keeps computer clocks equal, UDP 123. *Who uses it:* every server, router, and phone. *Why attackers care:* time servers keep peer and client lists, and old versions answered `monlist` with the last clients.

NFS (Network File System). *What:* mounts a remote Unix folder as if it were local, port 2049. *Who uses it:* Linux and Unix file servers. *Why attackers care:* wide exports (`*`) let anyone read or write files, and `no_root_squash` lets a remote root act as local root.

RPC (Remote Procedure Call). *What:* lets a program call a function on another computer. *Who uses it:* Windows services (port 135) and Unix services such as NFS (port 111). *Why attackers care:* the mapper lists every service and its port, which shows what to attack.

ISAKMP and IKE. *What:* the handshake that builds an IPsec VPN tunnel, UDP 500. *Who uses it:* site-to-site and remote-access VPNs. *Why attackers care:* replies reveal algorithms, and aggressive mode can leak a crackable PSK hash.

SIP (Session Initiation Protocol). *What:* sets up and ends voice and video calls, port 5060. *Who uses it:* IP phones and PBX systems. *Why attackers care:* it is clear text, shows extensions, and enables toll fraud, SPIT, and vishing.

LDAP. *What:* a protocol for searching a directory such as Active Directory, port 389. *Who uses it:* logins, address books, and apps. *Why attackers care:* it holds every user, group, and email address.

SNMP. *What:* reads and sets values on network devices, UDP 161. *Who uses it:* monitoring systems. *Why attackers care:* default community strings give the whole device map.

NetBIOS. *What:* old Windows naming and session service, ports 137 to 139. *Who uses it:* legacy Windows file sharing. *Why attackers care:* name tables reveal hosts, domains, and services.

finger, rwho, rusers. *What:* old Unix "who is online" tools. *Who uses it:* old Unix labs. *Why attackers care:* they hand out login names and real names.

6.8 Acronyms Used in This Module

Acronym	Meaning
AXFR	Full DNS zone transfer
IXFR	Incremental DNS zone transfer
ASN	Autonomous System Number

Acronym	Meaning
CN, OU, DC, DN	LDAP name parts: common name, org unit, domain, full path
DSA	Directory System Agent (LDAP server process)
FQDN	Fully Qualified Domain Name
IKE	Internet Key Exchange
ISAKMP	Internet Security Association and Key Management Protocol
LDAP	Lightweight Directory Access Protocol
MIB	Management Information Base
NBT	NetBIOS over TCP/IP
NFS	Network File System
NMS	Network Management Station
NSE	Nmap Scripting Engine
NSEC	Next Secure (DNSSEC record)
NTLM	NT LAN Manager (Windows authentication)
NTP	Network Time Protocol
OID	Object Identifier
PBX	Private Branch Exchange (phone system)
PDC	Primary Domain Controller
PSK	Pre-Shared Key
RID	Relative Identifier (last part of a Windows SID)
RPC	Remote Procedure Call
SA	Security Association
SID	Security Identifier
SIP	Session Initiation Protocol
SMB	Server Message Block
SMTP	Simple Mail Transfer Protocol
SNMP	Simple Network Management Protocol
SPIT	Spam over Internet Telephony
STARTTLS	Command that upgrades a plain connection to TLS
VoIP	Voice over IP
VRFY, EXPN	SMTP commands: verify user, expand list

7. Attack vs Countermeasure and Look-alike Comparisons

7.1 Attacks and Their Countermeasures

Attack	Countermeasure	Source
NetBIOS enumeration	Turn off NetBIOS over TCP/IP; block 137-139	Added
Share listing (net view)	Remove shares; tighten permissions; block 139 and 445	Slides and added
SNMP enumeration	Remove agent or turn off the service	Slide
SNMP with default strings	Change community string names	Slide
SNMP sniffing	Upgrade to SNMPv3	Slide
SNMP anonymous access	Group Policy: Additional restrictions for anonymous connections	Slide
LDAP enumeration (clear text)	Use SSL or STARTTLS	Slide
LDAP user guessing	Login name different from email; account lockout	Slide
LDAP unauthorized reads	NTLM, Kerberos, or basic authentication	Slide
NTP enumeration	Restrict queries; disable monlist; patch ntpd	Added
NFS enumeration	Proper permissions on exports	Slide
NFS network access	Firewall rule blocking port 2049	Slide
NFS misconfiguration	Correct /etc/exports and /etc/hosts.allow	Slide
NFS abuse tracking	Log requests to NFS files	Slide
SMTP user discovery	Hide server info in responses	Slide
SMTP relay abuse	Disable open relay	Slide
SMTP brute force	Limit connections per source	Slide
SMTP error leaks	Give limited info in error messages	Slide
SMB enumeration	Disable SMB on web, DNS, internet-facing servers	Slide
SMB port exposure	Disable TCP 139 and 445	Slide
SMB null sessions	RestrictNullSessAccess in the Registry	Slide
DNS zone transfer	Audit zones; allow AXFR only to secondaries	Slide and added
DNS resolver abuse	Resolver reachable only from inside	Slide
DNS reply forging	Random source ports for requests	Slide
DNS software bugs	Update and patch name servers	Slide
DNSSEC zone walking	Use NSEC3; remove stale records	Added
IPsec enumeration	Strong algorithms; no aggressive mode	Added
VoIP enumeration	Voice VLAN; SIP over TLS; SRTP	Added
RPC enumeration	Block 135 and 111 from untrusted networks	Added
Unix user enumeration	Disable finger, rwhod, rusersd	Added

7.2 Look-alike Pairs

Pair	Difference in one line	How to tell them apart
Scanning vs enumeration	Scanning finds open ports; enumeration queries services	"Active connection, directed queries" = enumeration
nbtstat vs netstat	NetBIOS names vs TCP connections	NetBIOS in the question
nbtstat -a vs -A	Name vs IP address	Capital A = Address
net view vs net use	List shares vs connect to a share	"List" vs "map a drive"
NetBIOS 137/139 vs SMB 445	Names and sessions vs direct SMB	139 needs NetBIOS; 445 does not
Code 1B vs 1D	Domain master browser vs subnet master browser	PDC = 1B
Code 03 vs 20	Messenger vs file server	Files = 20
UNIQUE vs GROUP	One owner vs shared name	Host = UNIQUE; domain = GROUP
Community public vs private	Read-only vs read-write	Private can change data
SNMPv1/2c vs v3	Clear text vs encrypted	"Encrypts passwords" = v3
Port 161 vs 162	Agent requests vs traps	Trap = 162
snmpwalk vs snmp-check	Raw dump vs formatted report	"Readable report" = snmp-check
LDAP 389 vs LDAPS 636	Plain vs TLS	S = secure
STARTTLS vs LDAPS	Upgrade on 389 vs dedicated 636	"Upgrade" = STARTTLS
ntptrace vs ntpq vs ntpdc	Chain vs performance vs daemon	Look for trace, performance, operation
showmount vs rpcinfo	Exports vs RPC programs	"Exported directories" = showmount
NFS 2049 vs portmapper 111	NFS itself vs the RPC directory	Program 100003 = nfs
VRFY vs EXPN	One user vs a list or alias	"Mailing list" = EXPN
VRFY vs RCPT TO	Special command vs normal delivery step	RCPT works when VRFY is off
250 vs 550	User exists vs unknown	5xx = failure
AXFR vs IXFR	Full zone vs changes only	"X" in AXFR = All
Zone transfer vs zone walking	Ask for the zone vs follow NSEC chain	NSEC = walking
NSEC vs NSEC3	Plain names vs hashed names	"Hashed" = NSEC3
Amass passive vs active	No contact vs contact and brute force	-brute = active
dig vs nslookup	Linux detail vs Windows interactive	"ls -d" = nslookup
ISAKMP vs ESP	Key setup vs data encryption	UDP 500 = ISAKMP
IKE main vs aggressive	Hidden identity vs fast and leaky	Aggressive leaks PSK hash
SIP 5060 vs 5061	Clear text vs TLS	5061 = TLS
SPIT vs vishing	Spam calls vs voice phishing	SPIT = bulk; vishing = scam

Pair	Difference in one line	How to tell them apart
rusers vs rwho vs finger	Remote users vs LAN users vs user detail	Phone and name = finger
enum4linux vs nullinux	Many checks vs null session focus	"Null" = nullinux
SMB vs NFS	Windows sharing vs Unix sharing	Export list = NFS
Enumeration vs footprinting	Active inside vs passive outside	Intranet = enumeration

8. Exam Cheat Sheet

8.1 Keyword to Answer

If the question says	Think
Active connection and directed queries	Enumeration
16 ASCII characters, 15 plus 1	NetBIOS name
NetBIOS name table of a remote computer	nbtstat
IP range with NetBIOS names and MACs	NetBIOS Enumerator
Shared resources of a remote host	net view
Default community strings	SNMP enumeration
Walk the MIB	snmpwalk
Directory system agent, TCP 389	LDAP enumeration
Chain of NTP servers to the primary source	ntptrace
Monitors operation of the NTP daemon	ntpdc
Monitors ntpd and determines performance	ntpq
Exported directories	showmount -e
Open NFS port and service	rpcinfo -p
Validates users in SMTP	VRFY
Delivery addresses of aliases and lists	EXPN
Defines recipients of a message	RCPT TO
Zone transfer with nslookup	ls -d
AXFR with dig	dig @server domain axfr
NSEC records walked	DNSSEC zone walking
LDNS and DNSRecon	DNSSEC zone walking tools
Map attack surface, OWASP	Amass
dns-nsec-enum.nse	Nmap DNSSEC enumeration
Knock, Subfinder, Raccoon, Turbolist3r	DNS enumeration tools
ISAKMP UDP 500	IPsec VPN gateway
Encryption, hash, auth type, key group, lifetime	ike-scan
SIP ports 5060 and 5061	VoIP enumeration
svmap	SIP device scan
Distributed client/server programs	RPC enumeration
Login name, real name, office phone	finger
Remote machines users	rusers
OS banner grabbing on port 445	SMB enumeration
SMBMap, enum4linux, nullinux	SMB tools
RestrictNullSessAccess	SMB countermeasure
Additional restrictions for anonymous connections	SNMP countermeasure

If the question says	Think
SSL or STARTTLS	LDAP countermeasure
Block port 2049	NFS countermeasure
Disable open relay	SMTP countermeasure

8.2 Must-Memorize Lists

Information an intruder enumerates (8): network resources, network shares, routing tables, audit and service settings, SNMP and FQDN details, machine names, users and groups, applications and banners.

NetBIOS codes (slide): 00 hostname or domain, 03 messenger, 20 server service, 1D master browser for subnet, 1B domain master browser (PDC).

NetBIOS enumeration tools (5): nbtstat, NetBIOS Enumerator, Nmap, Global Network Inventory, Advanced IP Scanner (plus Hyena).

SNMP enumeration tools (slide): SnmpWalk, Nmap, snmp-check, SoftPerfect Network Scanner, Network Performance Monitor, OpUtils.

LDAP enumeration tools (slide): Softerra LDAP Administrator, ldapsearch, AD Explorer, LDAP Admin Tool.

NTP commands (3): ntptrace, ntpdc, ntpq.

NFS tools and commands: RPCScan, SuperEnum, showmount -e, rpcinfo -p.

SMTP commands (3): VRFY, EXPN, RCPT TO. **SMTP tools (4):** Nmap, Metasploit, smtp-user-enum, NetScanTools Pro.

DNS zone transfer tools (3): nslookup, dig, DNSRecon. **DNSSEC walking tools (2):** LDNS, DNSRecon.

Amass commands (3): enum -passive -src, enum -active -brute -w, track -last 2.

DNS enumeration tools (4): Knock, Subfinder, Raccoon, Turbolist3r.

IPsec data from ike-scan (4): encryption and hashing algorithm, authentication type, key distribution algorithm, SA LifeDuration.

VoIP data (5): gateways and servers, IP-PBX systems, client software and phones, user-agent IP addresses, user extensions.

VoIP attacks (6): DoS, session hijacking, caller ID spoofing, eavesdropping, SPIT, vishing.

Linux user commands (3): rusers, rwho, finger.

SMB tools (4): Nmap, SMBMap, enum4linux, nullinux.

Countermeasure keys: SNMP = remove agent, change strings, SNMPv3, Group Policy. LDAP = SSL or STARTTLS, different username, account lockout, NTLM or Kerberos. NFS = permissions, block 2049, config files, logging. SMTP = hide info, no open relay,

connection limits, short errors. SMB = disable on web, DNS, and internet-facing servers, close 139 and 445, RestrictNullSessAccess. DNS = internal resolver, random ports, audit zones, patch.

8.3 Numbers and Defaults

Item	Value
NetBIOS name length	16 characters (15 + 1)
SNMP agent / trap	UDP 161 / UDP 162
Default SNMP read / write string	public / private
LDAP / LDAPS / Global Catalog	389 / 636 / 3268
NTP	UDP 123
NFS / portmapper	2049 / 111
SMTP	TCP 25
DNS zone transfer	TCP 53
ISAKMP	UDP 500 (NAT-T 4500)
SIP (slide)	2000, 2001, 5060, 5061
SMB	TCP 445 (and 139)
MS RPC mapper	135
NetBIOS name / datagram / session	UDP 137 / UDP 138 / TCP 139
finger	TCP 79
NFS program number	100003
Administrator RID / Guest RID	500 / 501

8.4 Pick the BEST Option Rules

1. If the question says "which command lists exported NFS folders", choose `showmount -e`, not `rpcinfo -p`.
2. If both `nbtstat -a` and `nbtstat -A` appear for an IP, choose `-A`. If the slide wording appears with `-a` and an IP, accept it.
3. For SNMP defense, the most complete answer is "upgrade to SNMPv3" because it adds encryption. "Change community strings" is the second best.
4. For LDAP defense, "use SSL or STARTTLS" beats "use a firewall" because the slide fix encrypts the traffic.
5. For SMTP user discovery that works when VRFY is off, choose RCPT TO.
6. For a zone transfer that fails, the correct reading is "the server is configured correctly".
7. For a signed zone where AXFR is refused, choose zone walking (NSEC).
8. For quiet DNS recon of a target, choose Amass `-passive`.
9. For a VPN gateway check, choose UDP 500 and ike-scan.

10. For SMB defense, pick the answer that includes "disable TCP 139 and 445" or "RestrictNullSessAccess".
11. For AI questions, choose "AI builds the command, the tester verifies and stays in scope".
12. When two tools both fit, pick the one the slide names for that service.

8.5 Last-Minute Mnemonics

- **Info list:** Naughty Nephews Rarely Admit Stealing Many Unripe Apples.
- **NetBIOS codes:** 00 Who, 03 Messages, 20 Files, 1B Big boss, 1D Director, 1E Elections.
- **NTP:** trace = Track, dc = Daemon Control, q = Quality.
- **SMTP:** VRFY = Verify one, EXPN = Expand many, RCPT = Reach recipient.
- **Amass:** Peek, Approach, Bang.
- **ike-scan data:** A-A-K-L = Algorithms, Authentication, Key group, Lifetime.
- **Countermeasures:** SNMP = v3, LDAP = TLS, NFS = 2049, SMB = 139 and 445, SMTP = no relay.

9. Practice Questions

All questions are original. Each answer and explanation is placed directly below its question.

Q1. During an internal test, a scan shows UDP 161 open on a switch at 10.10.1.1. The tester wants every value the device exposes, using the default read-only string. Which command fits best?

- A. `nbtstat -A 10.10.1.1`
- B. `snmpwalk -v1 -c public 10.10.1.1`
- C. `showmount -e 10.10.1.1`
- D. `ldapsearch -x -H ldap://10.10.1.1`

Answer: B. UDP 161 is SNMP, and snmpwalk walks the whole MIB with `-v` (version) and `-c` (community string).

- A is wrong: nbtstat reads NetBIOS name tables, not SNMP.
- C is wrong: showmount lists NFS exports.
- D is wrong: ldapsearch queries LDAP on TCP 389.

Q2. An nbtstat table shows the entry `LAB-DOM <1B> UNIQUE Registered`. What does this entry identify?

- A. The messenger service of a logged-in user
- B. The file server service of a host
- C. The domain master browser, which identifies the PDC
- D. The workstation name of a host

Answer: C. Code 1B is the domain master browser name and marks the primary domain controller (PDC).

- A is wrong: the messenger service uses code 03.
- B is wrong: the server service uses code 20.
- D is wrong: the workstation or host name uses code 00.

Q3. A tester on a Windows PC knows only the IP address 10.10.1.11 and wants the NetBIOS name table of that host. Following the official Microsoft switch meaning, which command is best?

- A. `nbtstat -n 10.10.1.11`
- B. `nbtstat -c 10.10.1.11`
- C. `nbtstat -R 10.10.1.11`
- D. `nbtstat -A 10.10.1.11`

Answer: D. The capital `-A` takes an IP address and returns the remote name table. (The slide shows `-a` with an IP, but when both are offered, `-A` is the IP form.)

- A is wrong: `-n` lists local names only.
- B is wrong: `-c` shows the local name cache.

- C is wrong: `-R` purges and reloads the cache.

Q4. A tester runs `net view \\10.10.1.22 /all` and sees `ADMIN$`, `C$`, and `IPC$` in the list. What does the `/all` switch add to the output?

- A. Hidden administrative shares whose names end in `$`
- B. A list of every domain in the forest
- C. A list of every user account on the host
- D. A mapped network drive for each share

Answer: A. `/all` includes hidden administrative shares such as ADMIN$ and C$.

- B is wrong: `net view /domain` lists domains.
- C is wrong: net view lists shares, not accounts.
- D is wrong: mapping a drive is done with `net use`.

Q5. A router must keep SNMP running because the monitoring team needs it. The risk team wants the strongest protection against passwords and messages being read on the network. What is the best action?

- A. Change the community string to a longer word
- B. Upgrade to SNMPv3
- C. Block UDP 162 only
- D. Rename the router in the MIB

Answer: B. SNMPv3 encrypts passwords and messages and adds authentication.

- A is wrong: v1 and v2c still send the string in clear text, so this only helps against simple guessing.
- C is wrong: UDP 162 carries traps; requests use 161.
- D is wrong: a name change does not protect traffic.

Q6. A tester captures traffic and sees usernames and department names in clear text from a directory service on TCP 389. What is the best fix?

- A. Disable DNS zone transfers
- B. Change the SNMP community strings
- C. Use SSL or STARTTLS to encrypt LDAP traffic
- D. Block NFS port 2049

Answer: C. LDAP is unsecured by default, and SSL or STARTTLS encrypts it.

- A is wrong: zone transfer is a DNS issue.
- B is wrong: community strings belong to SNMP.
- D is wrong: port 2049 is NFS.

Q7. An administrator wants to follow the chain of NTP servers from an internal time server up to the primary time source. Which command does that?

- A. `ntptrace`
- B. `ntpdc -c monlist`

- C. `rpcinfo -p`
- D. `finger`

Answer: A. ntptrace traces a chain of NTP servers back to the primary source.

- B is wrong: monlist lists recent clients of a server.
- C is wrong: rpcinfo lists RPC programs.
- D is wrong: finger is a Unix user tool.

Q8. The command `showmount -e 10.10.1.9` returns `Export list for 10.10.1.9:` and the line `/home *`. What does the `*` mean?

- A. Only the local host may mount `/home`
- B. The export is read-only
- C. The export is disabled
- D. Any client may mount `/home`

Answer: D. The wildcard allows any client, which is a weak setting that should be limited to named hosts.

- A is wrong: a local-only export would name localhost.
- B is wrong: read-only is a separate option (`ro`) and does not appear here.
- C is wrong: a disabled export would not be listed.

Q9. An `rpcinfo -p 10.10.1.13` listing contains the line `100003 3 tcp 2049 nfs`. What does this line show?

- A. An SNMP agent on port 2049
- B. An NFS service listening on TCP port 2049
- C. The RPC portmapper
- D. Only the NFS lock manager

Answer: B. Program 100003 is NFS, and the line shows version 3 on TCP 2049.

- A is wrong: SNMP uses UDP 161.
- C is wrong: the portmapper is program 100000 on port 111.
- D is wrong: the lock manager is `nlockmgr`, program 100021.

Q10. A tester connects to a mail gateway with telnet on port 25. She wants to see every real address behind the alias `staff` in a single command. Which SMTP command is best?

- A. `VRFY staff`
- B. `HELO staff`
- C. `EXPN staff`
- D. `QUIT staff`

Answer: C. EXPN shows the actual delivery addresses of aliases and mailing lists.

- A is wrong: VRFY checks one user and does not expand a list.
- B is wrong: HELO only greets the server.
- D is wrong: QUIT ends the session.

Q11. On a mail gateway, `VRFY admin` returns `502 Command not implemented`, and EXPN is also refused. The tester still needs to confirm which mailboxes exist. What is the best next step?

- A. Send `MAIL FROM:` and then test names with `RCPT TO:`
- B. Switch to an SNMP walk of the gateway
- C. Run `showmount -e` against the gateway
- D. Stop, because user discovery is impossible

Answer: A. RCPT TO is part of normal delivery. It often still answers `250` or `550` when VRFY and EXPN are disabled.

- B is wrong: SNMP does not list mailboxes.
- C is wrong: showmount is for NFS exports.
- D is wrong: RCPT TO still works on many servers.

Q12. Which SMTP server setting stops outsiders from using the server to forward mail from anyone to anyone?

- A. Enable the VRFY command
- B. Show the full software version in the banner
- C. Raise the limit of connections per source
- D. Disable the open relay feature

Answer: D. The slide lists "disable open relay" as an SMTP countermeasure.

- A is wrong: enabling VRFY helps enumeration.
- B is wrong: the slide says to remove sensitive server information from responses.
- C is wrong: the slide says to limit connections to stop brute force.

Q13. A tester runs `dig @ns1.example.com example.com axfr` and the only output line is `; Transfer failed.` What is the best conclusion?

- A. The dig program is broken
- B. The server refuses zone transfers, so it is set up correctly against this attack
- C. The domain does not exist
- D. DNSSEC is switched on for the zone

Answer: B. A failed or refused transfer means the server does not give its zone to this client.

- A is wrong: the tool ran and reported a clear result.
- C is wrong: a missing domain would give an NXDOMAIN answer.
- D is wrong: DNSSEC does not change AXFR behavior in this way.

Q14. A DNS zone is signed with NSEC records, and AXFR is refused. The tester still wants a list of names in the zone. What is the best next step?

- A. Run `showmount -e` on the name server
- B. Run `nbtstat -A` on the name server
- C. Walk the zone with `ldns-walk` or `dnsrecon -z`

- D. Run `smtp-user-enum` against the name server

Answer: C. Following the NSEC chain (zone walking) lists names even when AXFR is blocked.

- A is wrong: showmount is for NFS.
- B is wrong: nbtstat reads NetBIOS names.
- D is wrong: smtp-user-enum tests mail users.

Q15. The command `dnsrecon -d www.certifiedhacker.com -z` begins with the line `DNSSEC is not configured for www.certifiedhacker.com`. What is the correct reading?

- A. `-z` asks for a DNSSEC zone walk. The zone is unsigned, so the tool falls back to standard record lookups.
- B. `-z` asks for a zone transfer, and it succeeded.
- C. `-z` asks for a reverse lookup of the whole range.
- D. `-z` asks for a brute-force wordlist attack.

Answer: A. The `-z` flag performs a DNSSEC zone walk. With no DNSSEC there is nothing to walk.

- B is wrong: a zone transfer uses `-t axfr`.
- C is wrong: reverse lookups use a range option such as `-r`.
- D is wrong: brute force uses `-t brt` with `-D`.

Q16. A tester wants to map sub-domains of a target with the smallest chance of touching the target's own DNS servers. Which command is best?

- A. `amass enum -active -d example.com -brute -w all.txt`
- B. `amass track -d example.com -last 2`
- C. `amass enum -brute -d example.com`
- D. `amass enum -passive -d example.com -src`

Answer: D. Passive mode uses public data sources only, and `-src` shows which source found each name.

- A is wrong: active mode with brute force contacts the target.
- B is wrong: track compares earlier results; it is not a new passive discovery.
- C is wrong: brute force sends many guesses to DNS.

Q17. In `amass track -config c.ini -dir amass4owasp -d example.com -last 2`, what does `-last 2` do?

- A. It runs two brute-force threads
- B. It compares the last two enumerations
- C. It limits results to two sub-domains
- D. It waits two seconds between queries

Answer: B. The slide describes this command as tracking or comparing the last two enumeration scans.

- A is wrong: threads are not set with `-last`.
- C is wrong: the flag does not limit the result count.
- D is wrong: it sets no delay.

Q18. Which Nmap command correctly lists running processes through SNMP on 10.10.1.22?

- A. `nmap -sS -p 161 --script=snmp-processes 10.10.1.22`
- B. `nmap -sT -p 161 --script=snmp-processes 10.10.1.22`
- C. `nmap -sU -p 161 --script=snmp-processes 10.10.1.22`
- D. `nmap -sU -p 445 --script=snmp-processes 10.10.1.22`

Answer: C. SNMP uses UDP, so the scan type is `-sU` and the port is 161.

- A is wrong: `-sS` is a TCP SYN scan.
- B is wrong: `-sT` is a TCP connect scan.
- D is wrong: port 445 is SMB, not SNMP.

Q19. A scan of a public range shows `500/udp open isakmp` on 10.10.1.22. What does this most likely mean, and which tool gives more detail?

- A. An IPsec VPN gateway; ike-scan
- B. An SNMP agent; snmpwalk
- C. An LDAP server; ldapsearch
- D. An NFS server; showmount

Answer: A. ISAKMP on UDP 500 points to an IPsec VPN gateway. ike-scan then reads the encryption and hash algorithm, authentication type, key group, and SA lifetime.

- B is wrong: SNMP is UDP 161.
- C is wrong: LDAP is TCP 389.
- D is wrong: NFS is port 2049.

Q20. `ike-scan 10.10.1.22` prints `Notify message 14 (NO-PROPOSAL-CHOSEN)`. What is the best reading?

- A. No VPN service exists on the host
- B. The host is offline
- C. The host runs Windows
- D. The gateway is alive but rejected the proposal ike-scan sent

Answer: D. A notify reply proves an IKE service answered. It just did not accept the sample transform.

- A is wrong: a reply means IKE exists.
- B is wrong: an offline host sends no reply.
- C is wrong: the message says nothing about the OS.

Q21. An attacker maps SIP phones on UDP 5060 and then sends bulk unwanted calls to every extension. Which attack is this?

- A. Vishing
- B. SPIT
- C. Caller ID spoofing
- D. Session hijacking

Answer: B. SPIT is spam over Internet telephony: bulk unsolicited calls.

- A is wrong: vishing is a voice phishing scam aimed at one person to get data.
- C is wrong: caller ID spoofing fakes the number shown, which is not described here.
- D is wrong: hijacking takes over a live call.

Q22. A tester finds TCP 135 open on a Windows server and wants to see which RPC services it offers. What is port 135 (ADDED CONTEXT)?

- A. The NFS export port
- B. The Unix portmapper
- C. The Microsoft RPC endpoint mapper
- D. The LDAP global catalog

Answer: C. Port 135 is the Microsoft RPC endpoint mapper. Enumerating it shows the RPC services and their ports.

- A is wrong: NFS is 2049.
- B is wrong: the Unix portmapper is 111.
- D is wrong: the global catalog is 3268.

Q23. In a Unix lab, a tester wants the real name, home directory, shell, last login, and `.plan` text for the user `ubuntu`. Which command is best?

- A. `finger ubuntu`
- B. `rwho`
- C. `rusers -a`
- D. `net view`

Answer: A. finger returns user details such as login name, real name, shell, login time, and plan.

- B is wrong: rwho lists who is logged in on the LAN, with little detail.
- C is wrong: rusers lists logged-in users of remote machines.
- D is wrong: net view is a Windows share command.

Q24. A Windows file server answers on TCP 445 and allows null sessions. Which Registry parameter does the slide name for restricting anonymous access?

- A. EnableNullSessions
- B. DisableSMB1
- C. NetBIOSOptions

- D. RestrictNullSessAccess

Answer: D. The SMB countermeasures slide names `RestrictNullSessAccess` in the Windows Registry.

- A is wrong: this is not the name the slide uses.
- B is wrong: it concerns an SMB version, not anonymous access.
- C is wrong: it is not the parameter the slide lists.

Q25. A tester types `sgpt --shell "Perform IPsec enumeration on target IP 10.10.1.22 with nmap"`. ShellGPT prints a command and offers `[E]xecute, [D]escribe, [A]bort`. What is the best practice?

- A. Press E at once, because the AI is always right
- B. Press D to read the explanation, check flags and scope, then run it if correct
- C. Paste the client's whole network diagram into the chat first
- D. Always press A, because AI commands are unsafe

Answer: B. The tester stays responsible. Review the command, confirm it is in scope, and then run it.

- A is wrong: AI can write wrong flags.
- C is wrong: pasting sensitive client data into an AI service risks a leak.
- D is wrong: AI output is useful when it is checked.

Q26. A generative AI tool answers the IPsec prompt with `nmap -sS -p 500 10.10.1.22`, and the scan shows nothing. What is the most likely reason?

- A. ISAKMP uses TCP 5000
- B. Nmap cannot scan VPN gateways
- C. ISAKMP runs over UDP, so the scan needs `-sU`
- D. ISAKMP works only on port 443

Answer: C. ISAKMP is UDP 500. A TCP SYN scan (`-sS`) cannot find it.

- A is wrong: the port is 500, not 5000.
- B is wrong: Nmap can detect ISAKMP.
- D is wrong: 443 is HTTPS.

Q27. A Linux file server shows `/home *` in its export list, and port 2049 is reachable from the whole network. Which action gives the best protection?

- A. Restrict exports to named users and hosts, set correct `/etc/exports` and `/etc/hosts.allow`, and block port 2049 with a firewall
- B. Enable VRFY on the mail server
- C. Upgrade to SNMPv3
- D. Disable DNS zone transfers

Answer: A. These are the NFS countermeasures from the slide: proper permissions, correct config files, and a firewall rule for 2049 (plus logging).

- B is wrong: VRFY is an SMTP command.
- C is wrong: SNMPv3 protects SNMP.
- D is wrong: DNS transfers are unrelated to NFS.

Q28. Which activity is enumeration rather than scanning?

- A. Sending a ping sweep over a subnet
- B. Running a SYN scan to list open ports
- C. Querying an SNMP agent with the community string `public` to read its ARP table
- D. Looking up a domain in a Whois database

Answer: C. Enumeration makes an active connection and sends directed queries to get details such as tables, users, and shares.

- A is wrong: a ping sweep finds live hosts (scanning).
- B is wrong: a SYN scan finds open ports (scanning).
- D is wrong: Whois is passive footprinting, not an active connection to the target.

10. Flashcards

- Q: What is enumeration? | A: An active connection to a target plus directed queries to extract usernames, machine names, shares, and services.
- Q: Which phase comes right before enumeration? | A: Scanning (finding live hosts and open ports).
- Q: How long is a NetBIOS name? | A: 16 ASCII characters: 15 for the device name and 1 suffix for the service type.
- Q: NetBIOS codes 00, 03, 20, 1B, 1D? | A: 00 hostname or domain, 03 messenger, 20 server service, 1B domain master browser (PDC), 1D master browser.
- Q: Which nbtstat switch takes an IP address? | A: -A (capital). The slide shows -a with an IP.
- Q: What does net view \host /all add? | A: Hidden administrative shares such as ADMIN$ and C$.
- Q: What are the default SNMP community strings? | A: public (read-only) and private (read-write).
- Q: SNMP ports? | A: UDP 161 for requests, UDP 162 for traps.
- Q: Best SNMP fix? | A: Upgrade to SNMPv3, which encrypts passwords and messages.
- Q: Which command walks an SNMP MIB? | A: snmpwalk -v1 -c public host.
- Q: Which scan flag finds SNMP, NTP, IKE, and SIP? | A: -sU (UDP scan).
- Q: LDAP port and server process? | A: TCP 389 and the directory system agent (DSA).
- Q: LDAP countermeasures? | A: SSL or STARTTLS, username different from email, account lockout, NTLM or Kerberos.
- Q: What does ntptrace do? | A: Traces a chain of NTP servers back to the primary source.
- Q: What does ntpdc do? | A: Monitors the operation of the NTP daemon, ntpd.
- Q: What does ntpq do? | A: Monitors ntpd operations and determines performance (-p prints peers).
- Q: NTP port? | A: UDP 123.
- Q: Which command lists NFS exports? | A: showmount -e host.
- Q: Which command lists RPC programs? | A: rpcinfo -p host (NFS is program 100003 on port 2049).
- Q: NFS countermeasures? | A: Proper permissions, block port 2049, correct /etc/exports and /etc/hosts.allow, log requests.
- Q: What does VRFY do? | A: Validates one user.
- Q: What does EXPN do? | A: Shows the real delivery addresses of aliases and mailing lists.
- Q: What does RCPT TO do? | A: Defines the recipients of a message; its replies show valid and invalid users.
- Q: What does 250 mean and what does 550 User unknown mean? | A: 250 = accepted (user exists). 550 = user does not exist.

- Q: SMTP countermeasures? | A: Hide server info, disable open relay, limit connections, short error messages.
- Q: What does "Transfer failed" mean after dig axfr? | A: The server refuses zone transfers (configured correctly).
- Q: Steps of a Windows zone transfer test? | A: nslookup, set querytype=ns, server ns, ls -d domain.
- Q: Which tools do DNSSEC zone walking? | A: LDNS (ldns-walk) and DNSRecon (-z), by following NSEC records.
- Q: Amass passive versus active? | A: Passive uses public sources only. Active also contacts the target and can brute force with -brute -w.
- Q: What does amass track -last 2 do? | A: Compares the last two enumerations.
- Q: Which Nmap scripts enumerate DNSSEC? | A: dns-nsec-enum.nse and dns-nsec3-enum.nse.
- Q: Which port shows an IPsec VPN gateway? | A: UDP 500 (ISAKMP), and ike-scan reads the algorithms, auth type, key group, and SA lifetime.
- Q: SIP ports on the slide? | A: 2000, 2001, 5060, and 5061 (UDP and TCP).
- Q: Name the VoIP attacks on the slide. | A: DoS, session hijacking, caller ID spoofing, eavesdropping, SPIT, vishing.
- Q: Which Linux commands list users? | A: rusers (remote machines), rwho (local network), finger (detailed user info).
- Q: Which tools and port does SMB enumeration use? | A: Nmap, SMBMap, enum4linux, nullinux on TCP 445.
- Q: SMB countermeasures? | A: Disable SMB on web, DNS, and internet-facing servers, close TCP 139 and 445, set RestrictNullSessAccess.
- Q: DNS countermeasures? | A: Resolver reachable only inside, random source ports, audit zones, patch name servers.
- Q: What is the ShellGPT safety prompt? | A: [E]xecute, [D]escribe, [A]bort. Review the command before you run it.

11. Glossary

- **A record:** DNS record that maps a host name to an IPv4 address.
- **Active Directory:** Microsoft directory service that stores users and computers and uses LDAP.
- **Aggressive mode:** Faster IKE exchange that can leak a pre-shared key hash.
- **Amass:** OWASP tool that maps a domain's attack surface.
- **Anonymous bind:** LDAP login with no username and no password.
- **AXFR:** Full DNS zone transfer.
- **Banner:** Text a service shows when you connect.
- **Community string:** Password-like text used by SNMP v1 and v2c.
- **Countermeasure:** Action that lowers the risk of an attack.
- **DSA:** Directory System Agent, the LDAP server process.
- **enum4linux:** Linux tool that pulls users, shares, and policy from SMB.
- **Enumeration:** Active connection and directed queries to extract account, share, and service data.
- **EXPN:** SMTP command that expands a mailing list or alias.
- **finger:** Unix command that shows user details.
- **FQDN:** Fully qualified domain name.
- **Hidden share:** Share whose name ends in `$`.
- **IKE:** Internet Key Exchange, which sets up IPsec tunnels.
- **ike-scan:** Tool that finds IKE gateways and reads their settings.
- **IPC$:** Hidden share used for inter-process communication and null sessions.
- **IPsec:** Protocol suite that encrypts and authenticates IP traffic.
- **ISAKMP:** Framework that carries IKE messages, UDP 500.
- **LDAP:** Protocol for reading directory services, TCP 389.
- **LDNS:** DNS library and tools including ldns-walk.
- **MIB:** Database of values on an SNMP device.
- **NetBIOS:** Old Windows naming and session service.
- **NFS:** Network File System, Unix folder sharing on port 2049.
- **NSE:** Nmap Scripting Engine.
- **NSEC:** DNSSEC record that names the next existing name.
- **NSEC3:** Hashed version of NSEC.
- **ntpdc:** Tool that monitors the NTP daemon.
- **ntpq:** Tool that queries NTP and checks performance.
- **ntptrace:** Tool that follows NTP servers to the primary source.
- **Null session:** SMB connection with an empty username and password.
- **OID:** Number path that names one SNMP value.
- **Open relay:** Mail server that forwards mail from anyone to anyone.
- **PDC:** Primary domain controller.

- **Portmapper:** RPC directory service on port 111.
- **RCPT TO:** SMTP command that names a recipient.
- **Resolver:** DNS server that answers lookups for clients.
- **RestrictNullSessAccess:** Registry parameter that limits anonymous SMB access.
- **RID cycling:** Asking for account numbers one by one to find all accounts.
- **RPC:** Remote Procedure Call.
- **rpcinfo:** Command that lists RPC programs and ports.
- **rusers:** Command that lists users on remote machines.
- **rwho:** Command that lists users on local network hosts.
- **SA:** Security Association, the agreed settings of an IPsec tunnel.
- **SIP:** Session Initiation Protocol for voice and video calls.
- **SMB:** Server Message Block, Windows file sharing on TCP 445.
- **SMBMap:** Tool that lists SMB shares and permissions.
- **SNMP:** Protocol that monitors and manages network devices, UDP 161.
- **snmpwalk:** Command that walks an SNMP MIB.
- **SPIT:** Spam over Internet telephony.
- **STARTTLS:** Command that upgrades a plain connection to TLS.
- **svmap:** SIPVicious tool that finds SIP devices.
- **Vishing:** Voice phishing over VoIP.
- **VRFY:** SMTP command that validates a user.
- **Zone transfer:** Copy of a DNS zone from one server to another.
- **Zone walking:** Listing a signed zone by following NSEC records.

12. Coverage Report

12.1 Page to Section Map

Page	Slide and topic	Guide sections
1	Slide 1, learning objectives	3.1
1	Slide 2, what is enumeration	3.2, 8.2
1	Slide 6, NetBIOS enumeration and name list	3.3, 6.2
1	Slide 7, nbtstat, NetBIOS Enumerator, other tools	3.4, 4.1, 5.1
2	Slide 8, Net View	3.5, 5.2
2	Slide 11, SNMP, SnmpWalk and Nmap, other tools	3.6, 4.2, 5.3, 5.4, 6.4
3	Slide 11 repeat (merged with page 2)	3.6
3	Slide 13, LDAP enumeration and tools	3.7, 4.2, 5.5
4	Slide 15, NTP and ntptrace, ntpdc, ntpq	3.8, 5.6, 5.7, 5.8
4	Slide 16, NFS, showmount, rpcinfo	3.9, 5.9, 5.10
5	Slide 19, SMTP VRFY, EXPN, RCPT TO	3.10, 5.11, 6.3
5	Slide 19 cont'd, SMTP tools	3.11, 4.3, 5.12, 5.13
6	Slide 21, DNS zone transfer (dig, nslookup)	3.12, 5.14, 5.15
6	Slide 23, DNSSEC zone walking (LDNS, DNSRecon)	3.13, 5.16, 5.17, 6.5
7	Slide 24, OWASP Amass	3.14, 5.18
7	Slide 25, DNS and DNSSEC with Nmap, DNS tools	3.15, 4.3
8	Slide 29, IPsec enumeration with AI (two copies merged)	3.16, 5.19, 5.20
9	Slide 30, VoIP enumeration	3.17, 5.13, 5.21, 6.6
9	Slide 31, RPC enumeration	3.18
10	Slide 32, Unix/Linux user enumeration (two copies merged)	3.19, 5.22, 5.23, 5.24
11	Slide 33, SMB enumeration with AI	3.20, 3.23, 5.25
11	Slide 38, countermeasures SNMP, LDAP, NFS	3.21, 7.1
12	Slide 39, countermeasures SMTP, SMB, DNS	3.22, 7.1

Tools, commands, ports, and terms from all pages also appear in sections 4 to 11.

12.2 [UNCLEAR] Items

1. Page 1, slide 1: the wording of objectives 03 to 06 is small. The grouping in 3.1 is the best reading.
2. Page 2, slide 11: the exact values in the SnmpWalk output and the source label under the screenshot. The command reading is `snmpwalk -v1 -c public 10.10.1.22`.
3. Page 3, slide 13: the manual and automated LDAP commands (best reading: ldapsearch and `nmap -p 389 --script ldap-search`).
4. Page 4, slide 15: the full sub-command lists inside the ntpdc and ntpq screenshots.

5. Page 4, slide 16: the tool name reads "RPSCan" on the slide; the tool is RPCScan.
6. Page 5, slide 19: the server IP in the telnet transcripts and the second valid name (read as "Ryder").
7. Page 5, slide 19 cont'd: the exact command lines for Nmap, Metasploit, and smtp-user-enum.
8. Page 6, slide 21: the domain typed after `ls -d` in the nslookup demo.
9. Page 7, slides 24 and 25: the Docker prefix of the Amass demo and the Nmap commands for DNS and DNSSEC.
10. Page 8, slide 29: the exact ike-scan flags and the Nmap command generated by ShellGPT.
11. Page 9, slides 30 and 31: the Metasploit SIP module name and the name of the second RPC tool.
12. Page 11, slide 33: the Nmap command generated for the SMB prompt.

12.3 Items to Double Check

- **Conflict with official syntax:** the slide shows `nbtstat -a` with an IP address. Microsoft documents `-a` for a name and `-A` for an IP.
- **Conflict inside the notes:** code 1D is GROUP in the slide table but UNIQUE in the nbtstat output. Microsoft lists 1D as UNIQUE (verify).
- The NFS countermeasure lists `/etc/smb.conf` (a Samba file). The main NFS file is `/etc/exports`.
- SIP ports 2000 and 2001 are listed on the slide without names (they may relate to Cisco SCCP, verify).
- Amass v4 changed or removed some sub-commands and flags used on the slide (verify for your version).
- ntpdc `-s` meaning, the extra ntptrace flags, and the monlist CVE number.
- The Registry path for `RestrictNullSessAccess`.
- ike-scan, svmap, and smtp-user-enum flag lists beyond the basics.
- `rwho` port (UDP 513) and `finger` port (TCP 79).
- All sample outputs in sections 3 and 5 that are not copied from slides are made up for teaching.
- Everything labeled ADDED CONTEXT (SNMP architecture, null sessions, RID cycling, NetBIOS suffix extras, IKE modes, section 3.23) comes from outside your notes.

12.4 Confirmation

Every line of the working inventory (pages 1 to 12, slides 1 to 39) is mapped to a section in the table above. Items that could not be read with certainty are listed in 12.2 with a best reading, and outside knowledge is labeled ADDED CONTEXT.